

A Compliance Checklist for Financial Institutions in Germany

November 2021



Contents

INTRODUCTION: A COMPLIANCE CHECKLIST FOR FINANCIAL INSTITUTIONS IN GERMANY	3	The Need for an Appropriate Outsourcing Agreement	53
OVERVIEW OF THE REGULATORY LANDSCAPE	6	Technical and Operational Risk Q&A	66
COMPLIANCE CHECKLIST	14	Privacy and IT Security Safeguards	75
PART 1: KEY CONSIDERATIONS	15	PART 2: CONTRACT CHECKLIST	97
Overview	15	FURTHER INFORMATION	119
Offshoring	27		
Compliance within your Organisation	31		

Introduction: A compliance checklist for financial institutions in Germany

OVERVIEW

Cloud computing is fast becoming the norm, not the exception, for financial institutions in Germany.

Like all technological advancements, cloud computing provides substantial benefits – but it also creates a complex new environment for financial institutions to navigate. These financial institutions rightly want and expect an unprecedented level of assurance from cloud service providers before they move to the cloud.

Microsoft is committed to providing a trusted set of cloud services to financial institutions in Germany. Our extensive industry experience, customer understanding, research, and broad partnerships give us a valuable perspective and unique ability to deliver the assurance that our financial institutions customers need.

This checklist is part of Microsoft's commitment to financial institutions in Germany. We developed it to help financial institutions in Germany adopt Microsoft cloud services with confidence that they are meeting the applicable regulatory requirements.

This document is intended to serve as a guidepost for financial institution customers conducting due diligence, including risk assessments, of Microsoft Online Services. The Online Services include those online services defined as "Core Online Services" in the Online Services Privacy and Security Terms (hereinafter, the "Online Services"). Customers are responsible for conducting appropriate due diligence, and this document does not serve as a substitute for such diligence or for a customer's risk assessment. While this paper focuses principally on Azure Core Services (referred to as "Azure"), Office 365

Services (referred to as "Office 365") and Dynamics 365 Services (referred to as "Dynamics 365"), unless otherwise specified, these principles apply equally to all Online Services. This includes the **Compliance Program for Microsoft Cloud**, which is built on these set of Online Services which provides for a set of capabilities to meet the needs of financial institutions, underlying a foundation of security and compliance across these services.

Please be aware that this document is based on the current situation at the time of the creation of the document. Taking into account that the regulatory environment as well as our catalogue of products and services and their respective technical features are continuously evolving, we recommend to always visit the Microsoft Trust Center (<https://www.microsoft.com/en-us/trust-center>) where Microsoft posts the most recent information related to its products and services.

WHAT DOES THIS CHECKLIST CONTAIN?

This checklist contains:

1. an **Overview of the Regulatory Landscape**, which introduces the relevant regulatory requirements in Germany;
2. a **Compliance Checklist**, which lists the regulatory issues that need to be addressed and maps Microsoft's cloud services against those issues; and
3. details of where you can find **Further Information**.

Continued Next Page »

Introduction: A compliance checklist for financial institutions in Germany (continued)

WHO IS THIS CHECKLIST FOR?

This checklist is aimed at financial institutions in Germany who want to use Microsoft cloud services. We use the term “financial institutions” broadly, to include any entity that is regulated or supervised by the Federal Financial Supervisory Authority and/or the European System of Financial Supervision, including banks, financial services providers, insurance companies, payment services providers and investment fund managers supervised by the Federal Financial Supervisory Authority, as well as banks supervised by the European Central Bank.

WHAT MICROSOFT CLOUD SERVICES DOES THIS CHECKLIST APPLY TO?

This checklist applies to Microsoft Office 365, Microsoft Dynamics 365 and Microsoft Azure. You can access relevant information about each of these services at any time via the [Microsoft Trust Center](#).

IS IT MANDATORY TO COMPLETE THE CHECKLIST?

No. In Germany, there is no mandatory requirement for financial institutions to complete a checklist to adopt Microsoft cloud services. However, through conversations with our many cloud customers in Germany, we understand that a checklist approach like this is helpful – first, as a way of understanding the regulatory requirements; second, as a way of learning more about how Microsoft cloud services can help financial institutions meet those regulatory requirements; third, as an internal framework for documenting compliance; and fourth, as a tool to streamline consultations with the regulators, if they are required. By reviewing and completing the checklist, financial institutions can

adopt Microsoft cloud services with confidence that they are complying with the requirements in Germany.

This checklist should be read in parallel with the applicable regulatory framework (in particular, in relation to the laws and regulations listed in the table below that provides an overview of the regulatory landscape) and the internal policies and procedures of financial institutions.

HOW SHOULD WE USE THE CHECKLIST?

- 1. Read:** We suggest you begin by reviewing the Overview of the Regulatory Landscape in the next section. This will provide useful context for the sections that follow.
- 2. Conduct a Risk Assessment:** Having done so, we suggest that you review the questions set out in the Compliance Checklist and the information provided as a tool to measure compliance against the regulatory framework. The information in this document is provided to help you conduct your risk assessment. It is not intended to replace, or be a substitute for, the work you must perform in conducting an appropriate risk assessment but rather to aid you in that process. Additionally, there are a variety of resources Microsoft makes available to you to obtain relevant information as part of conducting your risk assessment, as well as maintaining ongoing supervision of our services. The information is accessible via [Microsoft Compliance https://docs.microsoft.com/compliance](https://docs.microsoft.com/compliance) and the [Service Trust Portal](#).

Continued Next Page »

Introduction: A compliance checklist for financial institutions in Germany (continued)

Microsoft also provides extensive information enabling self-service audit and due diligence on performance of risk assessments through the **Compliance Manager**. This includes extensive detail on the security controls including implementation details and explanation of how the third party auditors evaluate each control. More specifically, Compliance Manager:

- **Enables customers to conduct risk assessments** of Microsoft cloud services. Combines the detailed information provided by Microsoft to auditors and regulators as part of various third-party audits of Microsoft's cloud services against various standards (such as International Organisation for Standardisation 27001:2013 and ISO 27018:2014) and information that Microsoft compiles internally for its compliance with regulations (such as the EU General Data Protection Regulation or mapping to other required controls) with the customer's own self-assessment of its organisation's compliance with applicable standards and regulations.
 - **Provides customers with recommended actions** and detailed guidance to improve controls and capabilities that can help them meet regulatory requirements for areas they are responsible for.
 - **Simplifies compliance workflow** and enables customers to assign, track, and record compliance and assessment-related activities, which can help an organisation cross team barriers to achieve their compliance goals. It also provides a secure repository for customers to upload and manage evidence and other artifacts related compliance activities, so that it can produce richly detailed reports in Microsoft Excel that document the compliance activities performed by Microsoft and a customer's organisation, which can be provided to auditors, regulators, and other compliance stakeholders.
- 3. Reach out for support:** If you need any additional support or have any questions, Microsoft's expert team is on hand to support you throughout your cloud project, right from the earliest stages of initial stakeholder engagement through to assisting in any required consultation with the relevant regulators. You can also access more detailed information online, as set out in the Further Information section.

Overview of the Regulatory Landscape

Are cloud services permitted?	Yes. This means that you can consider Microsoft cloud services for the full range of use-cases across your financial institution.
Who are the relevant regulators and authorities?	The European Banking Authority (EBA). The European Securities and Markets Authority (ESMA) The European Insurance and Occupational Pensions Authority (EIOPA) EU member states all have jurisdictional prudential regulators with oversight authority. Less significant banks, financial services providers, insurance companies, payment services providers and investment fund managers are supervised by the Federal Financial Supervisory Authority (Bundesanstalt für Finanzdienstleistungsaufsicht) (BaFin). For the ongoing supervision of less significant banks and financial services providers, BaFin is assisted by the German Central Bank (Bundesbank). Website: https://www.bafin.de/EN For significant banks, the European Central Bank (ECB) is the competent supervisory authority. Website: https://www.ecb.europa.eu/home
What regulations and guidance are relevant? (continued)	There are several requirements and guidelines that financial institutions should be aware of when moving to the cloud, including, but not limited to: 1. <u>MiFID Org Regulation (MOR)</u> 2. <u>EBA Guidelines on outsourcing arrangements</u> EBA/GL/2019/02 (EBA Outsourcing Guidelines); <u>EIOPA Guidelines on outsourcing to cloud service providers</u> EIOPA-BoS-20-002 (EIOPA Outsourcing Guidelines); <u>ESMA Guidelines on outsourcing to cloud service providers</u> ESMA50-164-4285 (ESMA Outsourcing Guidelines) (Note that all references to the guidelines in this Checklist will be to the EBA Outsourcing Guidelines) Solvency II Directive 2009/138/EC (SolDir) 3. <u>Solvency II Directive 2009/138/EC (SolDir)</u>

Continued Next Page »

Overview of the Regulatory Landscape (Continued)

What regulations
and guidance are
relevant?
(continued)

4. **Solvency II Commission Delegated Regulation (EU) 2015/35 (SolReg)**
 5. Sec. 25a and 25b of the **German Banking Act** (English version)
 6. BaFin, Circular 09/2017 (BA), **Minimum Requirements for Banks' Risk Management** (English version) (**MaRisk**)
 7. BaFin, Circular 10/2017 (BA), **Supervisory Requirements for IT in Financial Institutions** (English version) (**BAIT**)
 8. BaFin, Guidance note - **Guidance on Outsourcing to cloud- service providers** (German version) (**English version**) (**BaFin Guidance**)
 9. EU Commission, Art. 30-32 of the **Commission Delegated Regulation (EU) 2017/565** of 25 April 2016 supplementing Directive 2014/65/EU of the European Parliament and of the Council as regards organisational requirements and operating conditions for investment firms and defined terms for the purposes of that Directive (**DR EU/2017/565**)
 10. European Banking Association (EBA), **Final Report on EBA Guidelines on outsourcing arrangements**, EBA/GL/2019/02, 25 February 2019 (will enter into on force on 30 September 2019)
 11. Sec. 32 of the **German Insurance Supervision Act** (English version)
 12. Art. 274 of **Commission delegated Regulation (EU) 2015/35 of 10 October 2014** (English version)
 13. Sec. 26 of the **German Payment Services Supervision Act** (German version)
 14. Sec. 36 of the **German Investment Code** (German version)
 15. Art. 75 – 82 of **Commission Delegated Regulation (EU) Nr. 231/2013 of 19 December 2012** (English version)
-

Continued Next Page »

Overview of the Regulatory Landscape (Continued)

What regulations and guidance are relevant?

16. BaFin, Circular 02/2017 (VA), Minimum Requirements under Supervisory Law on the System of Governance of Insurance Undertakings (English version) (MaGo)
17. BaFin, Circular 01/2017 (WA), Minimum Requirements for the Risk Management of Capital Management Companies (German version) (KAMaRisk)
18. BaFin, Circular 10/2018 (VA), Supervisory Requirements for IT in Insurance Undertakings (English version) (VAIT)
19. BaFin, Consultation of a Circular on Supervisory Requirements for IT in Capital Management Companies (German version) (KAIT)
20. EU General Data Protection Regulation 2016/679 (GDPR)
21. Konferenz der Datenschutzbeauftragten des Bundes und der Länder sowie der Arbeitsgruppe Internationaler Datenverkehr des Düsseldorfer Kreises – Orientierungshilfe – Cloud Computing (German version)
22. The essay "When banks outsource IT services" (English version) published by BaFin on 28/02/2019 can be helpful to understand BaFin's approach towards cloud outsourcing

Overview of the Regulatory Landscape (Continued)

Is regulatory
approval required?

Under EU Regulations:

No. However, according to the EBA Outsourcing Guidelines, financial institutions must maintain an updated register of information on its outsourcing arrangements, including detailed information concerning critical or important functions, such that the financial institution would be able to adequately inform competent authorities in a timely manner about the outsourcing of such functions.

Exception: According to the SolDir, insurance and reinsurance undertakings shall, in a timely manner, notify the supervisory authorities prior to the outsourcing of critical or important functions or activities as well as of any subsequent material developments with respect to those functions or activities.

Under German Regulations:

No, regulatory approval for the use of cloud services is not generally required. However, financial institutions may face a notification requirement (but no requirement for regulatory approval) if the use of cloud services amounts to a material outsourcing (as set out below).

Whether a notification requirement applies will depend on the regulatory status of the relevant undertaking:

- **Banks and financial services providers:** No notification requirement
- **Insurance undertakings:** Prior notification to the competent supervisory authority of the intention to enter into a material outsourcing agreement with a draft version of the agreement enclosed
- **Payment services providers:** Prior notification to BaFin and Bundesbank of the intention to enter into a material outsourcing agreement; second notification after the outsourcing arrangement is implemented
- **Regulated Asset Managers (so-called: Capital Management Companies):** Notification to BaFin of all outsourcing arrangements before the outsourcing agreement enters into force (the relevant regime does not distinguish between a material and non-material outsourcing)

Overview of the Regulatory Landscape (Continued)

Are public cloud services sufficiently secure?

Yes.

Several financial institutions in the EU are already using public cloud services. In fact, public cloud typically enables customers to take advantage of the most advanced security capabilities and innovations because public cloud services generally adopt those innovations first and have a much larger pool of threat intelligence data to draw upon.

Are there any mandatory terms that must be included in the contract with the services provider?

Yes.

EBA Outsourcing Guidelines, MOR and SolReg stipulate some specific terms that financial institutions must ensure are incorporated in their cloud service agreements. In Part 2 of the Compliance Checklist, below, we have mapped these against the sections in the Microsoft contractual documents where you will find them addressed.

Pursuant to the EU General Data Protection Regulation 2016/679 (**GDPR**), agreements with service providers shall include all the requirements of Article 28 GDPR. In this respect, the agreement shall list the service provider's obligations to protect the security and confidentiality of data.

MaRisk and BaFin Guidance specify certain mandatory elements/clauses which must be included in outsourcing agreements of financial institutions (please see Part 2 below for further details).

Overview of the Regulatory Landscape (Continued)

Is there a concept similar to “material outsourcing arrangements”? (continued)

Yes. Under German supervisory law additional provisions on outsourcing apply to “material” outsourcing.

According to AT 9 MaRisk outsourcing is the commissioning of another enterprise to provide activities and processes relating to the execution of banking business, financial services or any of an institution’s other usual services that would otherwise be provided by the institution itself.

Whether an outsourcing arrangement can be deemed “material” needs to be assessed by the supervised undertaking. This assessment should be based on the risk that this arrangement could pose to the business of the undertaking.

In the event of a cloud outsourcing arrangement, risk factors to be considered should generally be pursuant to Sect. IV of the BaFin Guidance:

- the design of the cloud service used
- the critical nature of the tasks to be outsourced
- risks arising from the chosen service and delivery model
- financial, operational (e.g. system failure, sabotage) risks, including legal risks (e.g. law enforcement risks, data protection risks) and reputational risks
- considerations on the location of data storage and processing
- the suitability of the cloud provider (to be proofed by certificates based on common standards)
- risks in the event of outsourcing several tasks to the same cloud provider
- risks associated with supervisory restrictions in the countries in which the services are provided or the data are stored or processed
- an assessment of the geopolitical situation (general stability of policy and security) and applicable laws (including data protection laws) in the jurisdictions concerned, the enforcement rules applicable in those jurisdictions, including insolvency rules that would apply in the event of the failure of the cloud provider

Continued Next Page »

Overview of the Regulatory Landscape (Continued)

Is there a concept similar to “material outsourcing arrangements”?

- risks to the integrity, availability, confidentiality and authenticity of the services and of the data processed or stored, taking account of
 - possible access to data by other jurisdictions
 - risks due to different interfaces between internal and external systems
 - risks due to extraordinary termination of contract, e.g. loss of data, limited transferability of data to a new service provider
 - risks stemming from further relocations by the cloud provider

If the financial institution comes to the view that a cloud outsourcing arrangement needs to be treated as a material outsourcing, further prudential requirements will apply. This includes inter alia an appropriate and effective risk management regarding the outsourced activities, a proper monitoring of these activities and the conclusion of an outsourcing agreement that complies with all regulatory requirements.

As regards regulated asset managers (Capital Management Companies) a slightly different definition of outsourcing is applied which does not differentiate between material and non-material outsourcings.

Overview of the Regulatory Landscape (Continued)

Are transfers of data outside of Germany permitted?

Yes, however restrictions apply.

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (**GDPR**), which came into force on 25 May 2018, allows trans-border dataflows, subject to certain restrictions. In addition, local data protection regulations should be taken into account.

More information regarding GDPR compliance can be found [here](#).

How do more general German privacy laws apply to the use of cloud services by financial institutions?

To the extent personal data are moved to the cloud, the GDPR, as supplemented by the German Federal Data Protection Act, applies. You can learn more about how Microsoft's products help you comply with the GDPR [here](#).

In many cases, cloud services providers are involved as so-called data processors processing personal data on behalf, and subject to the instructions, of their customers. As such, it is mandatory to put in place a data processing agreement containing a number of requirements, e.g. the implementation of technical and organisational measures or the duty to erase or hand back personal data at the end of the service relationship. The German supervisory authorities have also emphasised the need to keep the customer informed of the place of data processing in the cloud. Under a data processing agreement, the processing of personal data is usually permitted.

To the extent personal data is transferred from the EU to a third country, specific safeguards must be put in place – in most cases, the parties enter into Standard Contractual Clauses (for processors) imposing a number of duties on the processor for the purpose of creating an adequate data protection level.

Compliance Checklist

HOW DOES THIS COMPLIANCE CHECKLIST WORK?

In the “**Question/requirement**” column, we outline the regulatory requirement that needs to be addressed, based on the underlying requirements.

In the “**Guidance**” column, we explain how the use of Microsoft cloud services address the requirement. Where applicable, we also provide **guidance** as to where the underlying requirement comes from and other issues you may need to consider.

Looking for something specific?

Search Document

HOW SHOULD WE USE THE COMPLIANCE CHECKLIST?

Every financial institution and every cloud services project is different. We suggest that you tailor and build on the guidance provided to develop your own responses based on your financial institution and its proposed use of cloud services.

WHICH PART(S) DO WE NEED TO LOOK AT?

There are two parts to this Compliance Checklist:

- in **Part 1**, we address the key compliance considerations that apply; and
- in **Part 2**, we list the contractual terms that must be addressed and we indicate where these can be found in Microsoft’s contract documents.

Part 1: Key Considerations

WHO DOES THIS PART 1 APPLY TO?

This Part 1 applies to all deployments of Microsoft cloud services (particularly, Office 365, Dynamics 365 and Azure) by financial institutions in Germany.

REF.	QUESTION / REQUIREMENT	GUIDANCE
A. OVERVIEW		
This section provides a general overview of the Microsoft cloud services		
1	Who is the service provider?	The service provider is the regional licensing entity for, and wholly-owned subsidiary of, Microsoft Corporation, a global provider of information technology devices and services, which is publicly listed in the USA (NASDAQ: MSFT). The regional licensing entity in Europe and consequently in Germany is Microsoft Ireland Operations Limited, registered in Ireland under commercial registration number 256796 and with tax registration number IE8256796U. The registered address of Microsoft Ireland Operations Limited is 70 Sir Rogerson's Quay, Dublin 2, Ireland and the phone number is +1 800 710 200. Microsoft's full company profile is available here: microsoft.com/en-us/investor/ Microsoft's Annual Reports are available here: microsoft.com/en-us/Investor/annual-reports.aspx
2	What cloud services are you using?	All references to information about your cloud services may be found here: https://www.microsoft.com/en-us/trust-center/product-overview. Through this link there is access to information about: • Microsoft Office 365 • Microsoft Dynamics 365 • Microsoft Azure

REF.	QUESTION / REQUIREMENT	GUIDANCE
3	What activities and operations will be outsourced to the service provider? (continued)	Paragraph 12 and Section 3 EBA Outsourcing Guidelines regarding the definition of outsourcing: an arrangement of any form between a financial institution and a service provider by which that service provider performs a process, a service or an activity that would otherwise be undertaken by the financial institution, the payment institution or the electronic money institution itself Article 2(3) MOR ‘outsourcing’ means an arrangement of any form between an investment firm and a service provider by which that service provider performs a process, a service or an activity which would otherwise be undertaken by the investment firm itself Article 13(28) SolDir ‘outsourcing’ means an arrangement of any form between an insurance or reinsurance undertaking and a service provider, whether a supervised entity or not, by which that service provider performs a process, a service or an activity, whether directly or by sub-outsourcing, which would otherwise be performed by the insurance or reinsurance undertaking itself AT 9 No. 1 MaRisk Outsourcing occurs when another company is commissioned to carry out activities and processes in connection with the performance of banking transactions, financial services or other typical services that would otherwise be provided by the financial institution itself. Civil law structures and agreements cannot rule out the existence of outsourcing from the outset. Sec. II of the BaFin Guidance The term “outsourcing” is used in this Guidance for “outsourcing” within the meaning of section 25b of the German Banking Act (Kreditwesengesetz – KWG), section 80 of the German Securities Trading Act (Wertpapierhandelsgesetz – WpHG), section 26 of the German Payment Services Oversight Act (Zahlungsdiensteaufsichtsgesetz – ZAG) and section 36 of the German Investment Code (Kapitalanlagegesetzbuch – KAGB), as well as for “outsourcing” within the meaning of Article 274 Commission Delegated Regulation (EU) 2015/35 and section 32 of the German Insurance Supervisory Act (Versicherungsaufsichtsgesetz – VAG) .

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
3	What activities and operations will be outsourced to the service provider? (continued)	This Compliance Checklist is designed for financial institutions using Office 365, Dynamics 365 and/or Azure. Each service is different and there are many different options and configurations available within each service. The response below will need to be tailored depending on how you intend to use Microsoft cloud services and which Online Services you use. The Online Services include those online services defined as “Core Online Services” in the Online Services Privacy and Security Terms (hereinafter, the “Online Services”). Your Microsoft contact can assist as needed. If using Office 365, services would typically include: • Microsoft Office applications (Outlook, Word, Excel, PowerPoint, OneNote and Access) • Exchange Online • OneDrive for Business, SharePoint Online, Microsoft Teams, Yammer Enterprise, Intune If using Dynamics 365, services would typically include: • Microsoft Dynamics 365 for Customer Service, Microsoft Dynamics 365 for Field Service, Microsoft Dynamics 365 for Project Service Automation, Microsoft Dynamics 365 for Sales and Microsoft Social Engagement • Microsoft Dynamics 365 for Finance and Operations (Enterprise and Business Editions), Microsoft Dynamics 365 for Retail and Microsoft Dynamics 365 for Talent If using Microsoft Azure, services would typically include: • Virtual Machines, App Service, Cloud Services • Virtual Network, Azure DNS, VPN Gateway • File Storage, Disk Storage, Site Recovery • SQL Database, Machine Learning • IoT Hub, IoT Edge

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
3	What activities and operations will be outsourced to the service provider?	• Data Catalog, Data Factory, API Management • Security Center, Key Vault, Multi-Factor Authentication • Azure Blockchain Service
4	Are these activities suitable for a cloud outsourcing? Especially with respect to your organisation's risk management and control?	Sec. III of the BaFin Guidance When developing its IT strategy, the financial institution is to include aspects on the use of cloud services. In addition, a financial institution should develop and document a process covering all steps of relevance for outsourcing to the cloud service provider, from the strategy, migration to the cloud, right through to the exit strategy. It is important for the financial institution to first review all relevant internal processes to determine whether these are ready for “the cloud” before it goes ahead with such outsourcing. In this context particularly risk management and control processes of the financial institution must be considered in addition to the items to be outsourced. Whilst reviewing whether the proposed outsourcing is suitable, customers should consider how moving the cloud might affect the internal fabric of the firm. Adopting the cloud may have structural, cultural and/or technological consequences for the firm. Such issues may be pinpointed through looking into some of the following: • Which business units and processes would be affected by the solution being considered? • Are there any resource limitations? • How flexible is the organisation to structural change and resource reassignment? • Is the workforce receptive or resistant to technology innovation? • What is the staff awareness of risk and security process? • What IT systems are in place now and how will the cloud service be integrated into any existing IT assets? Microsoft provides various materials to help you to perform and assess the compliance of Microsoft cloud services – including audit reports, security assessment documents, in-depth details of security and privacy controls, FAQs and technical white papers – at: https://docs.microsoft.com/en-us/compliance/.

REF.	QUESTION / REQUIREMENT	GUIDANCE
5	What type of cloud services would your organisation be using? (continued)	Paragraph 52 EBA Outsourcing Guidelines As part of their risk management framework, institutions and payment institutions should maintain an updated register of information on all outsourcing arrangements at the financial institution and, where applicable, at sub-consolidated and consolidated levels, ... , and should appropriately document all current outsourcing arrangements, distinguishing between the outsourcing of critical or important functions and other outsourcing arrangements... Paragraph 54(h) EBA Outsourcing Guidelines Aside from additional mandatory requirements stated in paragraph 54 EBA Outsourcing Guidelines the register should include at least the following information for all existing outsourcing arrangements: (h) in the case of outsourcing to a cloud service provider, the cloud service and deployment models, i.e. public/private/hybrid/community, and the specific nature of the data to be held as well as the locations (i.e. countries or regions) where such data will be stored. Paragraphs 30 and 31 EBA Outsourcing Guidelines and in particular: An outsourcing arrangement may relate to a function that is critical or important. Particular attention should be given to the assessment of the criticality or importance of functions if the outsourcing concerns functions related to core business lines and critical functions. Paragraph 27 EBA Outsourcing Guidelines Where an arrangement with a cloud service provider covers multiple functions, financial institutions should consider all aspects of the arrangement within their assessment, e.g. if the service provided includes the provision of data storage hardware and the backup of data, both aspects should be considered together AT 9 No. 4 MaRisk In general, activities and processes can be outsourced provided that the proper business organisation pursuant to section 25a (1) of the Banking Act is not impaired. Outsourcing shall not entail the delegation of the management board's responsibility to the external service provider. The management board's management tasks shall not be outsourced. Special criteria for outsourcing arrangements arise from the complete or partial outsourcing of the special functions risk control function, compliance function and internal audit function.

Continued Next Page »

REF	QUESTION / REQUIREMENT	GUIDANCE
5	What type of cloud services would your organisation be using?	Special criteria may also arise from specific legal regulations (e.g. regulations that apply to building and loan associations regarding the treasury risk management of their collective savings and loans or that apply to Pfandbrief banks regarding the management of the collateral register (Deckungsregisterführung) and the coverage calculation (Deckungsrechnung)). Sec. IV of the BaFin Guidance In the risk analysis, the content of the cloud service used, should be considered by the financial institution. With Microsoft cloud services, a range of options exists, including public and hybrid cloud, but given the operational and commercial benefits to customers, public cloud is increasingly seen as the standard deployment model for most institutions. If using Office 365 and/or Dynamics 365: Customers can configure the service such that core categories of data are stored at rest within the European Union. These categories of data are described in the interactive datacenters map at https://docs.microsoft.com/en-us/microsoft-365/enterprise/eu-data-storage-locations?view=o365-worldwide If using Azure: Customers can configure the service such that core categories of data are stored at rest within the European Union. These categories of data are described in the interactive datacenters map at: https://azure.microsoft.com/en-us/global-infrastructure/data-residency/.
6	What data will be processed by the service provider on behalf of the financial institution? (continued)	Paragraph 54 to 56 EBA Outsourcing Guidelines and in particular: Paragraph 54 The register should include at least the following information for all existing outsourcing arrangements: (c) a brief description of the outsourced function, including the data that are outsourced and whether or not personal data (e.g. by providing a yes or no in a separate data field) have been transferred or if their processing is outsourced to a service provider; (f) the country or countries where the service is to be performed, including the location (i.e. country or region) of the data;

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
6	What data will be processed by the service provider on behalf of the financial institution?	(h) in the case of outsourcing to a cloud service provider, the cloud service and deployment models, i.e. public/private/hybrid/community, and the specific nature of the data to be held and the locations (i.e. countries or regions) where such data will be stored; Paragraph 55 For the outsourcing of critical or important functions, the register should include at least the following additional information: (g) where applicable, the names of any sub-contractors to which material parts of a critical or important function are sub-outsourced, including the country where the sub-contractors are registered, where the service will be performed and, if applicable, the location (i.e. country or region) where the data will be stored; It is important to understand what data will be processed through Microsoft cloud services. You will need to tailor this section depending on what data you intend to store or process within Microsoft cloud services. The following are common categories of data that our customers choose to store and process in the Microsoft cloud services. • Customer data (including customer name, contact details, account information, payment card data, security credentials and correspondence). • Employee data (including employee name, contact details, internal and external correspondence by email and other means and personal information relating to their employment with the organisation). • Transaction data (data relating to transactions in which the organisation is involved). • Indices (for example, market feeds). • Other personal and non-personal data relating to the organisation's business operations as a financial institution.

REF.	QUESTION / REQUIREMENT	GUIDANCE
7	How is the issue of counterparty risk addressed through your choice of service provider? (continued)	Paragraph 69 EBA Outsourcing Guidelines Financial institutions should ensure in their selection and assessment process that the service provider is suitable Guidelines Article 31(2)(a) MOR Investment firms must ensure the service provider has the ability, capacity, sufficient resources, appropriate organisational structure supporting the performance of the outsourced functions, and any authorisation required by law to perform the outsourced functions, reliably and professionally Article 274(3)(a) and (5)(c) SolReg The management or supervisory body [of the insurance or reinsurance undertaking] shall ensure that a detailed examination is performed to ensure that the potential service provider has the ability, the capacity and any authorization required by law to deliver the required functions. The insurance or reinsurance undertaking shall verify that the service provider has the necessary financial resources to perform the additional tasks in a proper and reliable way, and that all staff of the service provider who will be involved in providing the outsourced functions or activities are sufficiently qualified and reliable AT 9 No. 9 MaRisk The financial institution shall appropriately manage the risks associated with material outsourced activities and processes and shall properly monitor the provision of the outsourced activities and processes. This shall include regularly evaluating the external service provider's performance on the basis of defined criteria. Sec. IV of the BaFin Guidance In the risk analysis, the financial institution shall carry out an assessment of the suitability of the cloud service provider (capabilities, infrastructure, financial situation, corporate law and regulatory status, etc.) The following is a summary of the factors that our customers typically tell us are important. To access more information about Microsoft compliance practices and support for customers, visit Microsoft Compliance and the Trust Center . a. Competence. Microsoft is an industry leader in cloud computing. Microsoft cloud services were built based on ISO/IEC 27001 and ISO/IEC 27018 standards, a rigorous set of global standards covering physical, logical, process and management controls. Microsoft offers the most comprehensive set of compliance offerings of any cloud

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
7	How is the issue of counterparty risk addressed through your choice of service provider? (continued)	service provider. A list of its current certifications is available at microsoft.com/en-us/trustcenter/compliance/complianceofferings. From a risk assurance perspective, Microsoft's technical and organisational measures are designed to meet the needs of financial institutions globally. Microsoft also makes specific commitments across its Online Services in its Product Terms available at https://www.microsoft.com/en-sg/Licensing/product-licensing/products.aspx. b. Track-record. Many of the world's top companies use Microsoft cloud services. There are various case studies relating to the use of Microsoft cloud services at customers.microsoft.com. Customers have obtained regulatory approvals (when required) and are using Online Services in all regions of the globe including Asia, North America, Latin America, Europe, Middle East and Africa. Key countries of adoption include, by way of example: the United States, Canada, Hong Kong, Singapore, Australia, Japan, Taiwan, Indonesia, United Arab Emirates, Malaysia, the United Kingdom, France, Germany, Italy, Spain, the Netherlands, Poland, Belgium, Denmark, Norway, Sweden, Czech Republic, Brazil, Luxembourg, Hungary, Mexico, Chile, Peru, Argentina, South Africa, and Israel. Office 365 has grown to have over 300 million users, including some of the world's largest organisations and financial institutions. Azure continues to experience rapid growth and has over 400 million users, and over 85% of the largest financial institutions use or have committed to use Azure services. c. Specific financial services credentials. Financial institution customers in leading markets, including in the UK, France, Germany, Australia, Singapore, Canada, the United States and many other countries have performed their due diligence and, working with their regulators, are satisfied that Microsoft cloud services meet their respective regulatory requirements. This gives customers confidence that Microsoft can help meet the high burden of financial services regulation and is experienced in meeting these requirements. d. Financial strength of Microsoft. Microsoft Corporation is publicly-listed in the United States and is amongst the world's largest companies by market capitalisation. Microsoft has a strong track record of stable profits. Its market capitalisation is in excess of USD \$2 trillion as of July 1, 2021, making it one of the top three capitalised companies on the planet, Microsoft has been in the top 10 global market capitalised countries since 2000, and, indeed, is the only company in the world to consistently place in the top 10 of global market capitalised firms in the past twenty years. Its full company profile is available here: microsoft.com/en-us/investor/ and its Annual Reports are available here: microsoft.com/en-us/Investor/annual-reports.aspx. Accordingly, customers should have no concerns regarding its financial strength.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
7	How is the issue of counterparty risk addressed through your choice of service provider?	e. Insurance coverage. Microsoft maintains self-insurance arrangements for most of the areas where third party insurance is typically obtained and can make certificates of insurance available upon request. Microsoft has taken the commercial decision to take this approach, and considers that this does not detrimentally affect its customers, given Microsoft's financial position set out in Microsoft's Annual Reports. f. Audit rights. The Microsoft Financial Services Amendment provides for rights of audit, and additional customer benefits, including (a) access to community events organized by Microsoft related to updates to the Online Services, Microsoft responses to regulator changes, and to provide additional feedback to Microsoft for further development of the Online Services; (b) submit a written request to meet with Microsoft's external auditors; (c) receive from Microsoft written responses to updated regulator guidance; (d) receive responses from Microsoft about Microsoft responses and changes to services based on regulatory changes; (e) access Microsoft personnel for raising questions and escalations relating to Microsoft cloud services; (f) receive communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of Microsoft cloud services, (2) Microsoft's risk-threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on the customer's use of Microsoft cloud services, and (g) receive access to a summary report of the results of Microsoft's third party penetration testing against Microsoft cloud services (e.g. evidence of data isolation among tenants in the multi-tenanted services).

REF.	QUESTION / REQUIREMENT	GUIDANCE
8	Does financial institution carry out a pre-outsourcing analysis? (continued)	Paragraph 61 EBA Outsourcing Guidelines requires that before entering into any outsourcing arrangement, financial institutions should (i) assess if the outsourcing arrangement concerns a critical or important function; (ii) assess if the supervisory conditions for outsourcing are met; (iii) identify and assess all of the relevant risks of the outsourcing arrangement; (iv) undertake appropriate due diligence on the prospective service provider; (v) identify and assess conflicts of interest that the outsourcing may cause. Article 31(1) MOR Investment firms outsourcing critical or important operational functions shall remain fully responsible for discharging all of their obligations under [MiFID] and shall comply with the following conditions: (a) the outsourcing does not result in the delegation by senior management of its responsibility; (b) the relationship and obligations of the investment firm towards its clients under the terms of Directive [MiFID] is not altered; (c) the conditions with which the investment firm must comply in order to be authorised in accordance with [MiFID], and to remain so, are not undermined; (d) none of the other conditions subject to which the firm's authorisation was granted is removed or modified. Article 31(2) MOR Investment firms shall exercise due skill, care and diligence when entering into, managing or terminating any arrangement for the outsourcing to a service provider of critical or important operational functions and shall take the necessary steps to ensure that the following conditions are satisfied: (a) the service provider has the ability, capacity, sufficient resources, appropriate organisational structure supporting the performance of the outsourced functions, and any authorisation required by law to perform the outsourced functions, reliably and professionally; (b) the service provider carries out the outsourced services effectively and in compliance with applicable law and regulatory requirements, and to this end the firm has established methods and procedures for assessing the standard of performance of the service provider and for reviewing on an ongoing basis the services provided by the service provider;

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
8	Does financial institution carry out a pre-outsourcing analysis?	Article 274(3) SolReg When choosing the service provider for any critical or important operational functions or activities, the administrative, management or supervisory body shall ensure that: (a) a detailed examination is performed to ensure that the potential service provider has the ability, the capacity and any authorisation required by law to deliver the required functions or activities satisfactorily, taking into account the undertaking's objectives and needs; (d) the general terms and conditions of the outsourcing agreement are clearly explained to the undertaking's administrative, management or supervisory body and authorised by them. AT 9 No. 2 MaRisk Financial institutions must, prior to the outsourcing, assess whether the function to be outsourced is considered as material. AT 9 No. 4 and 5 MaRisk Financial institutions must, prior to the outsourcing, assess whether the function can be outsourced (in general, activities and processes can be outsourced provided that the proper business organisation pursuant to section 25a (1) of the Banking Act is not impaired). Microsoft provides various materials to help you to perform and assess the compliance of Microsoft cloud services – including audit reports, security assessment documents, in-depth details of security and privacy controls, FAQs and technical white papers – at: https://docs.microsoft.com/en-us/compliance/.

REF.	QUESTION / REQUIREMENT	GUIDANCE
B. OFFSHORING Microsoft gives customers the opportunity to choose that certain core categories of data will be stored at-rest within specified regions as chosen by the customer. Within Europe, such regions (also referred to as “Geos”), include the Netherlands, Ireland and other jurisdictions within the European Union. This section only applies to the extent that data and services will be hosted outside of the European Union. This will depend on the configuration of Microsoft cloud services that you select. Your responses will need to be tailored accordingly.		
9	Will the proposed outsourcing require offshoring? If so, from which territory(ies) will the outsourced cloud services be provided and the location of the data? (continued)	Paragraphs 52 to 60 of the EBA Outsourcing Guidelines discuss the register of outsourcing, which shall include documentation of the nature of the data to be held and the locations where such data will be stored. In particular: Paragraph 54 The register should include at least the following information for all existing outsourcing arrangements: (f) the country or countries where the service is to be performed, including the location (i.e. country or region) of the data; (h) in the case of outsourcing to a cloud service provider, the cloud service and deployment models, i.e. public/private/hybrid/community, and the specific nature of the data to be held and the locations (i.e. countries or regions) where such data will be stored. Paragraph 55 For the outsourcing of critical or important functions, the register should include at least the following additional information: (g) where applicable, the names of any sub-contractors to which material parts of a critical or important function are sub-outsourced, including the country where the sub-contractors are registered, where the service will be performed and, if applicable, the location (i.e. country or region) where the data will be stored. Paragraph 57 Financial institutions should, upon request, make available to the competent authority all information necessary to enable the competent authority to execute the effective supervision of the payment institution, including, where required, a copy of the outsourcing agreement.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
9	Will the proposed outsourcing require offshoring? If so, from which territory(ies) will the outsourced cloud services be provided and the location of the data?	Sec. V.5. of the BaFin Guidance: The location of data storage must be known to the financial institution. This should include the specific location of the data centres. As a general rule, giving the name of the location (e.g. the town or city) will suffice for this purpose. However, if the financial institution should need the precise address of the data centre based on considerations of risk management, the cloud service provider should provide it. Microsoft provides data location transparency and allows customers to choose that Customer Data will be stored at-rest within the European Union, as in other jurisdictions wherever the customer chooses to store data at rest. Microsoft Azure, on which most Microsoft business cloud services are built, hosts multiple tenants in a highly-secure way through logical data isolation. Data storage and processing for our tenants is isolated from each other tenant. If using Office 365 and/or Dynamics 365: Where the customer is in the European Union, Microsoft will store core categories of data at rest within the European Union. These categories of data are described in the interactive datacenters map at https://www.microsoft.com/en-us/TrustCenter/Privacy/where-your-data-is-located. If using Azure: Customers can configure the service such that core categories of data are stored at rest within the European Union. These categories of data are described in the interactive datacenters

REF.	QUESTION / REQUIREMENT	GUIDANCE
10	What other risks have been considered in relation to the proposed outsourcing arrangement? (continued)	Paragraphs 64 to 68 of the EBA Outsourcing Guidelines discuss the appropriate risk assessment of the outsourcing arrangement. In particular: Paragraph 64 Financial institutions should assess the potential impact of outsourcing arrangements on their operational risk, should take into account the assessment results when deciding if the function should be outsourced to a service provider and should take appropriate steps to avoid undue additional operational risks before entering into outsourcing arrangements. Paragraph 65 The assessment should include, where appropriate, scenarios of possible risk events, including high-severity operational risk events. Within the scenario analysis, financial institutions should assess the potential impact of failed or inadequate services, including the risks caused by processes, systems, people or external events. Financial institutions, taking into account the principle of proportionality referred to in Section 1, should document the analysis performed and their results and should estimate the extent to which the outsourcing arrangement would increase or decrease their operational risk. The following are risk areas that our customers typically tell us are important. a. Political (i.e. cross-border conflict, political unrest etc.) Our customers know where their data is hosted. Microsoft reviews the political environments of the relevant jurisdictions where data is hosted, and maintains robust cloud exit planning guidelines and strategies to adjust quickly to instability in political environments or to otherwise respond to challenges within a jurisdiction where data is hosted. b. Country/socioeconomic Microsoft's datacenters are strategically located around the world, taking into account country and socioeconomic factors. The relevant locations constitute stable socioeconomic environments.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
10	What other risks have been considered in relation to the proposed outsourcing arrangement?	c. Infrastructure/security/terrorism Microsoft's datacenters around the world are secured to the same exacting standards, designed to protect customer data from harm and unauthorised access. This is outlined in more detail at microsoft.com/en-us/trustcenter/security. d. Environmental (i.e. earthquakes, typhoons, floods) Microsoft datacenters are built in seismically safe zones. Environmental controls have been implemented to protect the datacenters including temperature control, heating, ventilation and air-conditioning, fire detection and suppression systems and power management systems, 24-hour monitored physical hardware and seismically-braced racks. These requirements are covered by Microsoft's ISO/IEC 27001 accreditation. e. Legal Customers will have in place a binding negotiated contractual agreement with Microsoft in relation to the outsourced service, giving them direct contractual rights and maintaining regulatory oversight. The terms are summarised in Part 2.

REF.	QUESTION / REQUIREMENT	GUIDANCE
C. COMPLIANCE WITHIN YOUR ORGANISATION EBA requires that financial institutions have internal mechanisms and controls in place to properly manage the outsourcing. Although this is a matter for each financial institution, Microsoft provides some guidance, based on its experience of approaches taken by its customers. Ultimately this will need to be tailored for your financial institution to reflect its compliance practices.		
11	If the cloud service relates to a function that is critical or important, what processes does the financial institution have in place to assess it? (continued)	Paragraph 31 EBA Outsourcing Guideline When assessing whether an outsourcing arrangement relates to a function that is critical or important, financial institutions should take into account at least the following factors: i. whether the outsourcing arrangement is directly connected to the provision of banking activities or payment services for which they are authorised; ii. the potential impact of any disruption to the outsourced function or failure of the service provider to provide the service at the agreed service levels on a continuous basis; iii. the potential impact of the outsourcing arrangement on their ability to identify, monitor and manage all risks, comply with all legal and regulatory requirements, and conduct appropriate audits regarding the outsourced function; iv. the potential impact on the services provided to its clients; v. all outsourcing arrangements, the financial institution's aggregated exposure to the same service provider and the potential cumulative impact of outsourcing arrangements in the same business area; (vi) the size and complexity of any business area affected; vi. the possibility that the proposed outsourcing arrangement might be scaled up without replacing or revising the underlying agreement; vii. the ability to transfer the proposed outsourcing arrangement to another service provider, if necessary or desirable, both contractually and in practice, including the estimated risks, impediments to business continuity, costs and time frame for doing so;

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
11	If the cloud service relates to a function that is critical or important, what processes does the financial institution have in place to assess it?	viii. the ability to reintegrate the outsourced function into the financial institution, if necessary or desirable; ix. the protection of data and the potential impact of a confidentiality breach or failure to ensure data availability and integrity on the financial institution and its clients, including but not limited to compliance with the GDPR. AT 9 No. 2 MaRisk The risk analysis shall take into account all aspects of the outsourced activities and processes that are relevant to the financial institution (e.g. the material outsourcing risks, including potential risk concentrations and risks arising from subcontracting, suitability of the external service provider), whereby the intensity of the analysis shall depend on the nature, scale, complexity and riskiness of the outsourced activities and processes. Hence in the case of a material outsourcing with significant consequences – such as the complete or partial outsourcing of the special functions risk control function, compliance function or internal audit function or of core bank units – the financial institution must intensively consider whether and how it can ensure that the outsourced activities and processes can be integrated into its risk management. Sec. IV. of the BaFin Guidance provides for similar requirements as the EBA Outsourcing Guidelines.

REF.	QUESTION / REQUIREMENT	GUIDANCE
12	What processes does the financial institution have in place for functions that are non-critical or non-important, particularly with regard to audits on a risk-based approach?	Some provisions in the EBA Outsourcing Guidelines are only relevant for critical or important functions or provide for milder requirements with regard to non- critical or non-important functions. For example, the outsourcing of functions that are not critical or important, Paragraph 88 EBA Outsourcing Guidelines provides: For the outsourcing of functions that are not critical or important, financial institutions should ensure the access and audit rights according to paragraph 87 EBA Outsourcing Guidelines on a risk-based approach, considering the nature of the outsourced function and the related operational and reputational risks, its scalability, the potential impact on the continuous performance of its activities and the contractual period. Institutions and payment institutions should take into account that functions may become critical or important over time. AT 9 No. 3 MaRisk Outsourced activities and processes that are not regarded as material in terms of risk shall be subject to the general requirements relating to a proper business organisation pursuant to section 25a (1) of the Banking Act.

REF.	QUESTION / REQUIREMENT	GUIDANCE
13	How does the financial institution demonstrate that in assessing the options for outsourcing a critical or important function to a third party, it has undertaken certain steps by way of due diligence to ensure that the service provider is suitable? For example, must the financial institution prepare a business case for outsourcing the critical or important function; undertake a tender/ selection process for selecting the provider; undertake a due diligence review of the chosen service provider? (continued)	Paragraphs 70 to 73 EBA Outsourcing Guidelines Paragraph 70 With regard to critical and important functions, the following factors are important: the business reputation, appropriate and sufficient abilities, the expertise, the capacity, the resources (e.g. human, IT, financial), the organisational structure and, if applicable, the required regulatory authorisation(s) or registration(s) to perform the critical or important function in a reliable and professional manner to meet its obligations over the duration of the draft contract. Paragraph 71 Additional factors to be considered when conducting due diligence on a potential service provider include: a. its business model, nature, scale, complexity, financial situation, ownership and group structure; b. the long-term relationships with service providers that have already been assessed and perform services for the financial institution; c. whether the service provider is a parent undertaking or subsidiary of the financial institution, is part of the accounting scope of consolidation of the financial institution or is a member of or is owned by financial institutions that are members of the same institutional protection scheme to which the financial institution belongs; d. whether or not the service provider is supervised by competent authorities. Paragraph 72 Where outsourcing involves the processing of personal or confidential data, financial institutions should be satisfied that the service provider implements appropriate technical and organisational measures to protect the data. Paragraph 73 Financial institutions should take appropriate steps to ensure that service providers act in a manner consistent with their values and code of conduct. Sec. IV of the BaFin Guidance In the risk analysis, the financial institution shall carry out an assessment of the suitability of the cloud service provider (capabilities, infrastructure, financial situation, corporate law and regulatory status, etc.).

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
13	How does the financial institution demonstrate that in assessing the options for outsourcing a critical or important function to a third party, it has undertaken certain steps by way of due diligence to ensure that the service provider is suitable? For example, must the financial institution prepare a business case for outsourcing the critical or important function; undertake a tender/ selection process for selecting the provider; undertake a due diligence review of the chosen service provider? (continued)	The business reputation Many of the world's top companies use Microsoft cloud services. There are various case studies relating to the use of Microsoft cloud services at customers.microsoft.com. Customers have obtained regulatory approvals (when required) and are using Online Services in all regions of the globe including Asia, North America, Latin America, Europe, Middle East and Africa. Key countries of adoption include, by way of example: the United States, Canada, Hong Kong, Singapore, Australia, Japan, Taiwan, Indonesia, United Arab Emirates, Malaysia, Office 365 has grown to over 300 million users, including some of the world's largest organisations and financial institutions. Azure continues to experience rapid growth and has over 400 million users, and over 85% of the largest financial institutions use or have committed to use Azure services. Appropriate and sufficient abilities The factors listed below may be used to prepare a business case for the use of Microsoft Online Services: • Affordability. Microsoft Online Services make enterprise- class technologies available at an affordable price for small and mid-sized companies. • Security. Microsoft Online Services include extensive security to protect customer data. It should be satisfied that the service provider implements appropriate technical and organisational measures to protect the data. • Availability. Microsoft's datacenters provide first-rate disaster recovery capabilities, are fully redundant, and are geographically dispersed to ensure the availability of data, thereby protecting data from natural disasters and other unforeseen complications. Microsoft also provides a financially backed guarantee of 99.9% uptime for most of its Online Services. • Resiliency. Microsoft provides system availability and resiliency through its hyperscale cloud platform that is designed to prevent single points of failures by deploying multiple instances of an application to geo dispersed locations. Microsoft operates the Azure cloud across Availability Zones within each Azure region. There are over 60 Azure regions worldwide, each with numerous Availability Zones. As a result, Azure Cloud Services are architected to be resilient from region-level failures, with multiple resiliencies throughout the system in each region. When a cloud customer deploys its cloud virtual machines across at least two Availability Zones

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
13	How does the financial institution demonstrate that in assessing the options for outsourcing a critical or important function to a third party, it has undertaken certain steps by way of due diligence to ensure that the service provider is suitable? For example, must the financial institution prepare a business case for outsourcing the critical or important function; undertake a tender/ selection process for selecting the provider; undertake a due diligence review of the chosen service provider? (continued)	within an Azure region, Microsoft projects 99.99% uptime. This provides for high zone availability and mitigates the risk of any single data center going down while other systems are running in another availability zone. Appropriate customer configuration and use of Availability Zones and region pairs is important. Microsoft helps customers with recommendations on configuration of zone availability and regional pairs, and Azure Secure Score provides customers important guidance on configuration, and provides other guidance on resiliency measures. A white paper on Azure resiliency is available here. • IT control and efficiency. Microsoft Online Services perform basic IT management tasks—such as retaining security updates and upgrading back-end systems—that allow company IT employees to focus their energy on more important business priorities. IT staff retain control over user management and service configuration. The continuous nature of Microsoft Online Services in terms of managing updates, addressing security threats, and providing real-time improvements to the service are unmatched relative to traditional legacy private hosted cloud environments. • User familiarity and productivity. Because programs like Microsoft Office, Outlook, and SharePoint are hosted on the cloud, company employees can access information remotely from a laptop, PC, or Smartphone. The expertise Microsoft is an industry leader in cloud computing. Microsoft cloud services were built based on ISO/IEC 27001 and ISO/IEC 27018 standards, a rigorous set of global standards covering physical, logical, process and management controls. Microsoft offers the most comprehensive set of compliance offerings of any cloud service provider. A list of its current certifications is available at microsoft.com/en-us/trustcenter/compliance/complianceofferings. From a risk assurance perspective, Microsoft's technical and organisational measures are designed to meet the needs of financial institutions globally. Microsoft also makes specific commitments across its Online Services in its Product Terms available at https://www.microsoft.com/en-sg/Licensing/product-licensing/products.aspx. The capacity and resources (e.g. human, IT, financial) Microsoft's full company profile is available here: microsoft.com/en-us/investor/ and its Annual Reports are available here: microsoft.com/en-us/Investor/annual-reports.aspx.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
13	How does the financial institution demonstrate that in assessing the options for outsourcing a critical or important function to a third party, it has undertaken certain steps by way of due diligence to ensure that the service provider is suitable? For example, must the financial institution prepare a business case for outsourcing the critical or important function; undertake a tender/ selection process for selecting the provider; undertake a due diligence review of the chosen service provider? (continued)	The organisational structure Microsoft's full company profile is available here: microsoft.com/en-us/investor/ If applicable, the required regulatory authorisation(s) or registration(s) to perform the critical or important function in a reliable and professional manner to meet its obligations over the duration of the draft contract. To be addressed by the financial institution. Service provider's business model, nature, scale, complexity, financial situation, ownership and group structure. Microsoft Corporation is publicly-listed in the United States and is amongst the world's largest companies by market capitalisation. Microsoft has a strong track record of stable profits. Its market capitalisation is in excess of USD \$2 trillion as of July 1, 2021, making it one of the top three capitalised companies on the planet, Microsoft has been in the top 10 global market capitalised countries since 2000, and, indeed, is the only company in the world to consistently place in the top 10 of global market capitalised firms in the past twenty years. Its full company profile is available here: microsoft.com/en-us/investor/ and its Annual Reports are available here: microsoft.com/en-us/Investor/annual-reports.aspx. The long-term relationships with service providers that have already been assessed and perform services for the financial institution To be addressed by the financial institution. Whether the service provider is a parent undertaking or subsidiary of the financial institution, is part of the accounting scope of consolidation of the financial institution or is a member of or is owned by financial institutions that are members of the same institutional protection scheme to which the financial institution belongs. No.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
13	How does the financial institution demonstrate that in assessing the options for outsourcing a critical or important function to a third party, it has undertaken certain steps by way of due diligence to ensure that the service provider is suitable? For example, must the financial institution prepare a business case for outsourcing the critical or important function; undertake a tender/ selection process for selecting the provider; undertake a due diligence review of the chosen service provider?	Whether or not the service provider is supervised by competent authorities. No, Microsoft is not subject to direct regulatory supervision. Where outsourcing involves the processing of personal or confidential data, institutions and payment institutions should be satisfied that the service provider implements appropriate technical and organisational measures to protect the data. Please see Questions 44 and 46. Institutions and payment institutions should take appropriate steps to ensure that service providers act in a manner consistent with their values and code of conduct. In particular, with regard to service providers located in third countries and, if applicable, their sub- contractors, institutions and payment institutions should be satisfied that the service provider acts in an ethical and socially responsible manner and adheres to international standards on human rights (e.g. the European Convention on Human Rights), environmental protection and appropriate working conditions, including the prohibition of child labour. Microsoft undertakes to comply with all laws and regulations applicable to its provision of the Online Services that are generally applicable to all the IT service providers.

REF.	QUESTION / REQUIREMENT	GUIDANCE
14	Does the financial institution have a written policy, approved by the Board, relating to the outsourcing? (continued)	Paragraph 41 EBA Outsourcing Guidelines The management body of a financial institution that has outsourcing arrangements in place or plans on entering into such arrangements should approve, regularly review and update a written outsourcing policy and ensure its implementation, as applicable, on an individual, sub-consolidated and consolidated basis Article 274(1) SolReg Any insurance or reinsurance undertaking which outsources or proposes to outsource functions or insurance or reinsur-ance activities to a service provider shall establish a written outsourcing policy which takes into account the impact of out-sourcing on its business and the reporting and monitoring arrangements to be implemented in cases of outsourcing The appropriate policy will depend on the type of organisation and the Online Services in question, and will be proportional to the organisation's risk profile and the specific workloads, data, and purpose for using the Online Services. It will typically include: • a framework to identify, assess, manage, mitigate and report on risks associated with the outsourcing to ensure that the organisation can meet its financial and service obligations to its depositors, policyholders and other stakeholders; • the appropriate approval authorities for outsourcing depending on the nature of the risks in and materiality of the outsourcing (the policy itself needing to be approved by the board); • assessing management competencies for developing sound and responsive outsourcing risk management policies and procedures; • undertaking regular review of outsourcing strategies and arrangements for their continued relevance, safety and soundness; • ensuring that contingency plans, based on realistic and probable disruptive scenarios, are in place and tested; and • ensuring that there is independent review and audit for compliance with the policies.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
14	Does the financial institution have a written policy, approved by the Board, relating to the outsourcing?	You could use the information set out in Question 13 to develop your policy. For example, in describing the service provider selection process, you could include in your policy analysis of the factors listed above with respect to Microsoft's reputation and track record. In addition, you may consider including in the policy that, as part of Microsoft's certification requirements, Microsoft is required to undergo regular, independent third-party audits. As a matter of course, Microsoft already commits to annual audits and makes available those independent audit reports to customers. Customers also have audit rights pursuant to the Financial Services Amendment.
15	Does the financial institution have the right for its auditors and the relevant competent authorities to have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider to carry out audits regarding the outsourced function? (continued)	Section 13.3 EBA Outsourcing Guidelines (i.e. Paragraphs 85 to 97 EBA Outsourcing Guidelines) and in particular: Paragraph 87 Financial institutions should ensure within the written outsourcing agreement that the service provider grants them and their competent authorities, including resolution authorities, and any other person appointed by them or the competent authorities, the following: (a) full access to all relevant business premises (e.g. head offices and operation centres), including the full range of relevant devices, systems, networks, information and data used for providing the outsourced function, including related financial information, personnel and the service provider's external auditors ('access and information rights'); and (b) unrestricted rights of inspection and auditing related to the outsourcing arrangement ('audit rights'), to enable them to monitor the outsourcing arrangement and to ensure compliance with all applicable regulatory and contractual requirements. Article 31(2)(i) MOR The service provider shall ensure that the investment firm, its auditors and the relevant competent authorities have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider, where necessary for the purpose of effective oversight in accordance with this article, and the competent authorities are able to exercise those rights of access

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
15	Does the financial institution have the right for its auditors and the relevant competent authorities to have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider to carry out audits regarding the outsourced function? (continued)	AT 9 No. 7(b) and (c) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review and ensure that the competent authorities pursuant to section 25b (3) of the Banking Act retain unrestricted rights of information and review and the ability to supervise with regard to the outsourced activities and processes. Sec. V. 2 and 3 of the BaFin Guidance Information and audit rights as well as control possibilities of the financial institution and the supervisory authorities must not be subject to contractual restrictions. It has to be ensured that the financial institution receives the information it needs to adequately control and monitor the risks associated with the outsourcing. The supervisory authorities must be able to monitor cloud service providers exactly as the applicable law provides for the financial institution. The Microsoft Financial Services Amendment provides for rights of audit, and additional customer benefits, including (a) access to community events organized by Microsoft related to updates to the Online Services, Microsoft responses to regulator changes, and to provide additional feedback to Microsoft for further development of the Online Services; (b) submit a written request to meet with Microsoft's external auditors; (c) receive from Microsoft written responses to updated regulator guidance; (d) receive responses from Microsoft about Microsoft responses and changes to services based on regulatory changes; (e) access Microsoft personnel for raising questions and escalations relating to Microsoft cloud services; (f) receive communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of Microsoft cloud services, (2) Microsoft's risk-threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on the customer's use of Microsoft cloud services, and (g) receive access to a summary report of the results of Microsoft's third party penetration testing against Microsoft cloud services (e.g. evidence of data isolation among tenants in the multi-tenanted services).

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
15	Does the financial institution have the right for its auditors and the relevant competent authorities to have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider to carry out audits regarding the outsourced function?	In addition, Microsoft offers the optional Compliance Program for the Microsoft Cloud, which provides for (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in- person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.
16	What monitoring processes does the financial institution have in place to manage the outsourcing, and how is it taken into account into its risk management? (continued)	Paragraph 32 EBA Outsourcing Guidelines As part of the overall internal control framework, including internal control mechanisms, financial institutions should have a holistic institution-wide risk management framework extending across all business lines and internal units. Under that framework, institutions and payment institutions should identify and manage all their risks, including risks caused by arrangements with third parties. Article 31(2)(b) MOR Investment firms should have established methods and procedures for assessing the standard of performance of the service provider and for reviewing, on an ongoing basis, the services provided by the service provider.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
16	What monitoring processes does the financial institution have in place to manage the outsourcing, and how is it taken into account into its risk management? (continued)	Article 274(5)(b) SolReg The insurance or reinsurance undertaking that is outsourcing critical or important operational functions or activities shall adequately take account of the outsourced activities in its risk management and internal control. AT 9 No. 9 MaRisk The financial institution shall appropriately manage the risks associated with material outsourced activities and processes and shall properly monitor the provision of the outsourced activities and processes. This shall include regularly evaluating the external service provider's performance on the basis of defined criteria. AT 9 No. 7(b) and (c) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review and ensure that the competent authorities pursuant to section 25b (3) of the Banking Act retain unrestricted rights of information and review and the ability to supervise with regard to the outsourced activities and processes. The guidance below explains how certain features of Microsoft cloud services can make monitoring easier for you. In addition, you may sign up for Premier Support, in which a designated Technical Account Manager serves as a point of contact for day-to-day management of the Online Services and your overall relationship with Microsoft. As part of its certification requirements, Microsoft is required to undergo independent third-party auditing, and it shares with the customer the independent third party audit reports. Microsoft also makes available a wealth of resources online to provide transparency and assurance to customers in the Microsoft Compliance dashboard.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
16	What monitoring processes does the financial institution have in place to manage the outsourcing, and how is it taken into account into its risk management?	The Microsoft Financial Services Amendment provides for rights of audit, and additional customer benefits, including (a) access to community events organized by Microsoft related to updates to the Online Services, Microsoft responses to regulator changes, and to provide additional feedback to Microsoft for further development of the Online Services; (b) submit a written request to meet with Microsoft's external auditors; (c) receive from Microsoft written responses to updated regulator guidance; (d) receive responses from Microsoft about Microsoft responses and changes to services based on regulatory changes; (e) access Microsoft personnel for raising questions and escalations relating to Microsoft cloud services; (f) receive communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of Microsoft cloud services, (2) Microsoft's risk-threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on the customer's use of Microsoft cloud services, and (g) receive access to a summary report of the results of Microsoft's third party penetration testing against Microsoft cloud services (e.g. evidence of data isolation among tenants in the multi-tenanted services).
17	Does the financial institution have access to adequate, independent information in order to appropriately monitor the cloud service provider and the effectiveness of its controls? (continued)	Paragraph 87 EBA Outsourcing Guidelines Financial institutions should ensure within the written outsourcing agreement that the service provider grants them and their competent authorities, including resolution authorities, and any other person appointed by them or the competent authorities, the following: (a) full access to all relevant business premises (e.g. head offices and operation centres), including the full range of relevant devices, systems, networks, information and data used for providing the outsourced function, including related financial information, personnel and the service provider's external auditors ('access and information rights'); and (b) unrestricted rights of inspection and auditing related to the outsourcing arrangement ('audit rights'), to enable them to monitor the outsourcing arrangement and to ensure compliance with all applicable regulatory and contractual requirements. Sec. V. 8 of the BaFin Guidance Provisions are to be agreed ensuring that the cloud service provider informs the financial institution about developments that might adversely affect the orderly performance of the outsourced items. That includes things like reporting any disruptions in providing the cloud service. This is to ensure that the company can adequately monitor the outsourced item.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
17	Does the financial institution have access to adequate, independent information in order to appropriately monitor the cloud service provider and the effectiveness of its controls?	All customers and potential customers have access to information for monitoring the effectiveness of Microsoft's controls, including through the following online sources: • <u>Microsoft Compliance</u>, which offers a comprehensive set of compliance offerings as well as resources to gain an understanding of Microsoft security and privacy practices; • The Service Trust Portal, which provides confidential materials, such as third-party audit reports and vulnerability assessment reports, to current customers and potential customers testing Microsoft Online Services; • Compliance Manager, which provides detailed third party audit results enabling self-service audit and due diligence; • a publicly available <u>Trust Center</u> for Microsoft Online Services that includes non-confidential compliance information; • a <u>Compliance Program for the Microsoft Cloud</u>, which provides access to engineers with subject matter expertise concerning underlying controls of the Online Services; • the <u>Azure Security Center</u> and <u>Office 365 Advanced Threat Analytics</u>, which enable customers to seamlessly obtain cybersecurity-related information about Online Services deployments; • <u>Office 365 Secure Score</u>, which provides insight into the strength of customers' Office 365 deployment based on the customer's configuration settings compared with recommendations from Microsoft, and <u>Azure Advisor</u>, which enables customers to optimise their Azure resources for high availability, security, performance, and cost; • the <u>Office 365 Service Health Dashboard</u> and <u>Azure Status Dashboard</u>, which broadcast real-time information regarding the status of Microsoft Online Services; and • <u>Office 365 Advanced Threat Protection</u> and the <u>Azure Web Application Firewall</u>, which protect customer email in real-time from cyberattacks and provide customers with information security protections and analytics information.

REF.	QUESTION / REQUIREMENT	GUIDANCE
18	How does the financial institution ensure that it maintains ultimate responsibility for any outsourcing?	Paragraph 35 EBA Outsourcing Guidelines The outsourcing of functions cannot result in the delegation of the management body's responsibilities. Paragraph 37 EBA Outsourcing Guidelines Financial institutions remain fully responsible and accountable for complying with all of their regulatory obligations, including the ability to oversee the outsourcing of critical or important functions. Article 31(1)(a) MOR Investment firms outsourcing critical or important operational functions shall remain fully responsible for discharging all of their obligations [under MiFID]. Article 49(1) SolDir insurance and reinsurance undertakings remain fully responsible for discharging all of their obligations under [SolDir] when they outsource functions or any insurance or reinsurance activities. AT 9 No. 4 MaRisk In general, activities and processes can be outsourced provided that the proper business organisation pursuant to section 25a (1) of the Banking Act is not impaired. Outsourcing shall not entail the delegation of the management board's responsibility to the external service provider. The management board's management tasks shall not be outsourced. Financial institutions should have adequate competence and sufficient and appropriately skilled resources to ensure appropriate management and oversight of outsourcing arrangements The contract with Microsoft explicitly mentions the responsibilities of the parties and provides the customer with legal mechanisms to manage the relationship including appropriate allocation of responsibilities, oversight and remedies and the mandatory terms required by the EBA.

REF.	QUESTION / REQUIREMENT	GUIDANCE
19	How does the financial institution ensure that it has sufficient substance and does not become “empty shells” or “letter-box entities”?	Paragraph 39 EBA Outsourcing Guidelines Financial institutions should maintain at all times sufficient substance and not become ‘empty shells’ or ‘letter-box entities’. To this end, financial institutions should i. meet all the conditions of their authorisation at all times, including the management body effectively carrying out its responsibilities; ii. retain a clear and transparent organisational framework and structure that enables them to ensure compliance with legal and regulatory requirements; iii. (where operational tasks of internal control functions are outsourced (e.g. in the case of intragroup outsourcing or outsourcing within institutional protection schemes), exercise appropriate oversight and be able to manage the risks that are generated by the outsourcing of critical or important functions; and iv. have sufficient resources and capacities to ensure compliance with points (i) to (iii). AT 9 No. 4 MaRisk In general, activities and processes can be outsourced provided that the proper business organisation pursuant to section 25a (1) of the Banking Act is not impaired. Outsourcing shall not entail the delegation of the management board’s responsibility to the external service provider. The management board’s management tasks shall not be outsourced. AT 9 No. 5 MaRisk Activities and processes in control units and core bank units may be outsourced in compliance with the requirements set out in number 4 to a degree that ensures that the financial institution retains the expertise and experience needed to ensure the effective monitoring of services carried out by external service providers. Microsoft provides tools and resources to help map control requirements by the financial institution through Microsoft <u>compliance documentation dashboard</u>.

REF.	QUESTION / REQUIREMENT	GUIDANCE
20	Does the financial institution maintain a register of information on all outsourcing arrangements?	Paragraphs 52 and 54 (h) EBA Outsourcing Guidelines Financial institutions should maintain an updated register of information on all outsourcing arrangements at the financial institution (as part of their risk management framework). The register should include at least, in the case of outsourcing to a cloud service provider, the cloud service and deployment models, i.e. public/private/hybrid/community, and the specific nature of the data to be held as well as the locations (i.e. countries or regions) where such data will be stored. Paragraphs 30 and 31 EBA Outsourcing Guidelines An outsourcing arrangement may relate to a function that is critical or important. Particular attention should be given to the assessment of the criticality or importance of functions if the outsourcing concerns functions related to core business lines and critical functions. AT 9 No. 13 MaRisk Central outsourcing management shall draw up a report on material outsourcings at least once a year and make this available to the management board. Taking into account the information available to the financial institution or the financial institution's internal evaluation of the quality of the services provided by the external service provider, the report shall contain an assessment of whether the services provided by the external service providers correspond to the contractual agreements, whether the outsourced activities and processes can be appropriately managed and monitored and whether further risk mitigation measures are to be taken. An understanding of the type of cloud solution and its critical nature may be relevant when determining the risk associated with the solution. This is the customer's responsibility to manage. The customer may work with Microsoft through its account representative a list of services used in connection with an outsourcing arrangement.

REF.	QUESTION / REQUIREMENT	GUIDANCE
21	How does financial institution manage conflicts of interest?	Paragraphs 45 and 46 EBA Outsourcing Guidelines Financial institutions should identify, assess and manage conflicts of interests with regard to their outsourcing arrangements. Article 274(3)(b) SolReg When insurance companies choose the service provider for any critical or important operational functions or activities, the administrative, management or supervisory body shall ensure that the service provider has adopted all means to ensure that no explicit or potential conflict of interests jeopardize the fulfilment of the needs of the outsourcing undertaking. Choosing Microsoft as a service provider does not present any conflict of interest issues.
22	Does the financial institution run an internal audit function? (continued)	Paragraphs 50 and 51 EBA Outsourcing Guidelines Financial institutions should conduct a risk-based internal audit of the outsourced activities that at a minimum will ascertain (i) the financial institution's framework for outsourcing; (ii) the adequacy, quality, and effectiveness of the assessment of the criticality or importance of functions; (iii) the adequacy, quality, and effectiveness of the risk assessment to ensure it is in line with the financial institution's risk strategy; (iv) the appropriate involvement of governance bodies; and (v) the appropriate monitoring and management of outsourcing arrangements. AT 9 No. 12 MaRisk Depending on the nature, scale and complexity of the outsourcing activities, the financial institution shall establish a central outsourcing management. Its tasks shall include, in particular, (a) implementing and further developing an appropriate outsourcing management and corresponding control and monitoring processes, (b) creating and maintaining full documentation of outsourcings (including subcontracted activities and processes), (c) supporting the business units with regard to internal and statutory requirements for outsourcing, (d) coordinating and reviewing the risk analysis pursuant to number 2 conducted by the responsible units.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
22	Does the financial institution run an internal audit function?	A customer's internal audit function, may, as appropriate, conduct audits of the Online Services, including the ability to meet with Microsoft personnel and Microsoft's external auditors, and to access any related information, records, reports and documents, in the event that the regulator requests to examine the Online Services operations in order to meet their supervisory obligations. Customers may also participate in the optional Compliance Program for the Microsoft Cloud to obtain additional information concerning the Online Services, including the following: (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft. Additional information related to compliance management may be found in Microsoft Compliance, including at these references, which cover managing compliance in the cloud and other compliance management issues.
23	Does the financial institution have a documented exit strategy? (continued)	Paragraphs 106 to 107 EBA Outsourcing Guidelines and in particular: Paragraph 106 Financial institutions should have a documented exit strategy when outsourcing critical or important functions that is in line with their outsourcing policy and business continuity plans,⁵⁵ taking into account at least the possibility of: (a) the termination of outsourcing arrangements; (b) the failure of the service provider; (c) the deterioration of the quality of the function provided and actual or potential business disruptions caused by the inappropriate or failed provision of the function; (d) material risks arising for the appropriate and continuous application of the function.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
23	Does the financial institution have a documented exit strategy?	Paragraph 107 Financial institutions should ensure that they are able to exit outsourcing arrangements without undue disruption to their business activities, without limiting their compliance with regulatory requirements and without any detriment to the continuity and quality of its provision of services to clients AT 9 No. 6 MaRisk In the case of material outsourced activities and processes, it has to be ensured that in the event of termination the items outsourced to the cloud service provider continue to be provided until such time that the outsourced item has been completely transferred to another cloud service provider or to the financial institution. In this regard it has to be guaranteed in particular that the cloud service provider will reasonably assist the financial institution in transferring the outsourced items to another cloud service provider or directly to the financial institution. Microsoft agreements are usually subject to terms of 12-36 months, which may be extended at the customer's election. They also include rights to terminate early for cause and without cause. Microsoft's Financial Services Amendment provides for business continuity and exit provisions, including rights for the customer to obtain exit assistance at market rates from Microsoft Consulting Services. Customers should work with Microsoft to build such business continuity and exit plans. Microsoft's flexibility in offering hybrid solutions further facilitate transition from cloud to on-premise solutions more seamlessly. Microsoft provides resources for customers to address exit planning, including its exit planning guidelines for financial services institutions and exit planning white paper.
24	Does the financial institution assess the overall operational risks associated with the outsourced function and assign responsibility for managing them? (continued)	Background Sections 5 and 6 EBA Outsourcing Guidelines on sound governance arrangements in relation to outsourcing and third-party risk Outsourcing arrangements should not create undue operational risks or impair the quality and independence of financial institutions' internal controls or the ability of those financial institutions and the competent authorities to oversee and supervise compliance with regulatory requirements. Article 31(1) MOR Investment firms shall remain fully responsible for discharging all of their obligations and shall comply with the following conditions:

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
24	Does the financial institution assess the overall operational risks associated with the outsourced function and assign responsibility for managing them?	(a) the outsourcing does not result in the delegation by senior management of its responsibility; (b) the relationship and obligations of the investment firm towards its clients under the terms of [MiFID] is not altered; (c) the conditions with which the investment firm must comply in order to be authorised in accordance with Article 5 of [MiFID], and to remain so, are not undermined; (d) none of the other conditions subject to which the firm's authorisation was granted is removed or modified. Article 31(2)(e) MOR Investment firms shall exercise due skill, care and diligence when entering into, managing or terminating any arrangement for the outsourcing to a service provider of critical or important operational functions and shall take the necessary steps to ensure that the following conditions are satisfied: (e) the investment firm effectively supervises the outsourced functions or services and manage the risks associated with the outsourcing and to this end the firm retains the necessary expertise and resources to supervise the outsourced functions effectively and manage those risks; Article 49(2)(b) SolDir Outsourcing of critical or important operational functions or activities shall not be undertaken in such a way as to lead to any of the following: (b) unduly increasing the operational risk; AT 9 No. 10 MaRisk The financial institution shall clearly specify the responsibilities for managing and monitoring material outsourced activities and processes. Sec. I of the BaFin Guidance An outsourcing may not result in the responsibility of managers of the financial institution for the items outsourced being transferred to the cloud service provider. The financial institution continues to be responsible for compliance with the statutory provisions to be observed by the supervised companies. Microsoft offers a combination of tools and resources which are specifically designed to facilitate this risk assessment, including Microsoft Compliance and the Service Trust Portal which offer access to a deep set of security, privacy and compliance resources.

REF.	QUESTION / REQUIREMENT	GUIDANCE
D. THE NEED FOR AN APPROPRIATE OUTSOURCING AGREEMENT Note: See also Part 2 of this Compliance Checklist for a list of the standard contractual terms that EBA Outsourcing Guidelines require to be included in the outsourcing agreement and how these are addressed by the Microsoft contractual documents. This section D also includes reference to certain issues that the regulator suggests are considered as part of the contractual negotiation but which are not necessarily mandatory contractual terms that should be included in all cases.		
25	Are the outsourcing arrangements contained in a documented legally binding agreement that is signed by all parties?	Section 13 (particularly Paragraphs 74 and 75) EBA Outsourcing Guidelines on the contractual phase Article 31(3) MOR The respective rights and obligations of the investment firms and of the service provider shall be clearly allocated and set out in a written agreement. Article 274(3)(c) SolReg A written agreement is entered into between the insurance or reinsurance undertaking and the service provider which clearly defines the respective rights and obligations of the undertaking and the service provider AT 9 No. 7 MaRisk on the contractual phase Sec. V of the BaFin Guidance on the contractual phase Microsoft enters into agreements with each of its financial institution customers for Online Services, which includes a Financial Services Amendment, the Product Terms, and the Service Level Agreement. The agreements clearly define the Online Services to be provided. The contractual documents are further outlined in Part 2, below.

REF.	QUESTION / REQUIREMENT	GUIDANCE
26	Is there a sufficiently detailed description of the services provided by the service provider?	AT 9 No. 7 lit. a) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall specify and, where appropriate, delineate the services to be provided by the external service provider. Microsoft enters into agreements with each of its financial institution customers for Online Services, which includes a Financial Services Amendment, the Product Terms, and the Service Level Agreement. The agreements clearly define the Online Services to be provided.
27	Does the outsourcing agreement include clauses that oblige the service provider to fully cooperate with the internal and external auditors of the financial institution and the regulator and that grants unrestricted access to the information, data and premises of the service provider including all data centres, equipment, systems and networks used to provide the outsourced services (continued)	AT 9 No. 7 lit. b) and c) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review, and ensure that the competent authorities pursuant to section 25b (3) of the Banking Act retain unrestricted rights of information and review and the ability. Sec. V. 2 and 3 of the BaFin Guidance Information and audit rights as well as control possibilities of the financial institution and the supervisory authorities must not be subject to contractual restrictions. It has to be ensured that the financial institution receives the information it needs to adequately control and monitor the risks associated with the outsourcing. The supervisory authorities must be able to monitor cloud service providers exactly as the applicable law provides for the financial institution The Microsoft Financial Services Amendment provides for rights of audit, and additional customer benefits, including (a) access to community events organized by Microsoft related to updates to the Online Services, Microsoft responses to regulator changes, and to provide additional feedback to Microsoft for further development of the Online Services; (b) submit a written request to meet with Microsoft's external auditors; (c) receive from Microsoft written responses to updated regulator guidance; (d) receive responses from Microsoft about Microsoft responses and changes to services based on regulatory changes; (e) access Microsoft personnel for raising questions and escalations relating to Microsoft cloud services; (f) receive communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of Microsoft cloud services, (2) Microsoft's risk-

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
27	and including the ability to conduct onsite inspections at the service provider's site as well as the sites of its delegates? Does the outsourcing agreement include any clause that could prevent the financial institution, its external auditors or the regulator from fully exercising such rights?	threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on the customer's use of Microsoft cloud services, and (g) receive access to a summary report of the results of Microsoft's third party penetration testing against Microsoft cloud services (e.g. evidence of data isolation among tenants in the multi-tenanted services). In addition, Microsoft offers an optional Compliance Program for the Microsoft Cloud, which provides for (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in- person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.
28	Does the outsourcing agreement include a clause that allows competent authorities to access documentation and information relating to the outsourcing arrangement? (continued)	Paragraphs 87 and 89 EBA Outsourcing Guidelines require that financial institutions should ensure that the outsourcing agreement does not impede or limit the effective exercise of the access and audit rights by them, competent authorities or third parties appointed by them to exercise these rights. Article 31(2)(h) MOR The service provider cooperates with the competent authorities of the investment firm in connection with the outsourced functions. Article 31(2)(i) MOR The investment firm, its auditors and the relevant competent authorities shall have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider, where necessary for the purpose of effective oversight in accordance with this article, and the competent authorities are able to exercise those rights of access

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
28	Does the outsourcing agreement include a clause that allows competent authorities to access documentation and information relating to the outsourcing arrangement? (continued)	Article 274(4)(h) SolReg The insurance or reinsurance undertaking, its external auditor and the supervisory authority shall have effective access to all information relating to the outsourced functions and activities including carrying out on-site inspections of the business premises of the service provider. Article 274(4)(i) SolReg Where appropriate and necessary for the purposes of supervision, the supervisory authority may address questions directly to the service provider to which the service provider shall reply. AT 9 No. 7(b) and (c) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review and ensure that the competent authorities pursuant to section 25b (3) of the Banking Act retain unrestricted rights of information and review and the ability to supervise with regard to the outsourced activities and processes. Sec. V. 2 and 3 of the BaFin Guidance Information and audit rights as well as control possibilities of the financial institution and the supervisory authorities must not be subject to contractual restrictions. It has to be ensured that the financial institution receives the information it needs to adequately control and monitor the risks associated with the outsourcing. The supervisory authorities must be able to monitor cloud service providers exactly as the applicable law provides for the financial institution. Yes. Microsoft fully commits to rights of audit to customers and rights of examination by regulators. The Financial Services Amendment provides customers and their auditors with the unrestricted rights of inspection and auditing related to the outsourcing arrangement, which includes specific rights of access to business premises for financial services customers via special contractual provisions designed for regulated customers in the financial services sector. Additionally, the Financial Services Amendment provides the customer's regulator to examine or audit the Online Services in order to meet the regulator's supervisory obligations of Microsoft as a direct service provider of the customer. These rights enable such customers to comply with their regulatory obligations through direct access to business premises, to information, Microsoft personnel and Microsoft's external auditor.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
28	Does the outsourcing agreement include a clause that allows competent authorities to access documentation and information relating to the outsourcing arrangement?	Customers may also participate in the optional Compliance Program for the Microsoft Cloud to obtain additional information concerning the Online Services, including the following: (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft. In addition to the foregoing, Microsoft makes available a broad set of resources available to customers from an assurance perspective.
29	Does the outsourcing agreement provide for data and system security requirements within the outsourcing agreement and does the financial institution monitor compliance with these requirements on an ongoing basis? (continued)	Paragraph 81 EBA Outsourcing Guidelines Financial institutions should ensure that service providers, where relevant, comply with appropriate IT security standards. Paragraph 82 EBA Outsourcing Guidelines Where relevant (e.g. in the context of cloud or other ICT outsourcing), institutions and payment institutions should define data and system security requirements within the outsourcing agreement and monitor compliance with these requirements on an ongoing basis Article 31(2)(c) MOR the service provider properly supervises the carrying out of the outsourced functions, and adequately manage the risks associated with the outsourcing; Article 31(2)(j) MOR the service provider protects any confidential information relating to the investment firm and its clients;

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
29	Does the outsourcing agreement provide for data and system security requirements within the outsourcing agreement and does the financial institution monitor compliance with these requirements on an ongoing basis? (continued)	Article 274(4)(f) and (5) SolReg the insurance or reinsurance undertaking reserves the right to be informed about the outsourced functions and activities and their performance by the services provider, and must ensure that relevant aspects of the service provider's risk management and internal control systems are adequate to comply with Article 49(2)(a) and (b) SolDir. AT 9 No. 7(e) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall include rules ensuring compliance with data protection provisions and other security requirements. Sec. V. 4 of the BaFin Guidance Provisions ensuring compliance with data protection regulations and other security requirements are to be agreed. Microsoft as an outsourcing partner is an industry leader in cloud security and implements policies and controls on par with or better than on-premises datacenters of even the most sophisticated organizations. Microsoft cloud services were built based on ISO/IEC 27001 and ISO/IEC 27018 standards, a rigorous set of global standards covering physical, logical, process and management controls. Microsoft has the broadest set of certifications in the industry, with details provided in the Azure compliance documentation. The Microsoft cloud services security features consist of three parts: (a) built-in security features; (b) security controls; and (c) scalable security. These include 24-hour monitored physical hardware, isolated customer data, automated operations and lock-box processes, secure networks and encrypted data. Microsoft implements the Microsoft Security Development Lifecycle (SDL) which is a comprehensive security process that informs every stage of design, development and deployment of Microsoft cloud services. Through design requirements, analysis of attack surface and threat modelling, the SDL helps Microsoft predict, identify and mitigate vulnerabilities and threats from before a service is launched through its entire production lifecycle. Networks within Microsoft's datacenters are segmented to provide physical separation of critical back-end servers and storage devices from the public-facing interfaces. Edge router security allows the ability to detect intrusions and signs of vulnerability. Customer access to services provided over the Internet originates from users' Internet-

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
29	Does the outsourcing agreement provide for data and system security requirements within the outsourcing agreement and does the financial institution monitor compliance with these requirements on an ongoing basis? (continued)	enabled locations and ends at a Microsoft datacenter. These connections are encrypted using industry-standard transport layer security TLS. The use of TLS establishes a highly secure client-to-server connection to help provide data confidentiality and integrity between the desktop and the datacenter. Customers can configure TLS between Microsoft cloud services and external servers for both inbound and outbound email. This feature is enabled by default. Microsoft also implements traffic throttling to prevent denial-of-service attacks. It uses the “prevent, detect and mitigate breach” process as a defensive strategy to predict and prevent security breaches before they happen. This involves continuous improvements to built-in security features, including port-scanning and remediation, perimeter vulnerability scanning, OS patching to the latest updated security software, network-level DDOS detection and prevention and multi-factor authentication for service access. Use of a strong password is enforced as mandatory, and the password must be changed on a regular basis. From a people and process standpoint, preventing breach involves auditing all operator/administrator access and actions, zero standing permission for administrators in the service, “Just-In-Time (JIT) access and elevation” (that is, elevation is granted on an as-needed and only-at-the-time-of-need basis) of engineer privileges to troubleshoot the service, and isolation of the employee email environment from the production access environment. Employees who have not passed background checks are automatically rejected from high privilege access, and checking employee backgrounds is a highly scrutinized, manual- approval process. Preventing breach also involves automatically deleting unnecessary accounts when an employee leaves, changes groups, or does not use the account prior to its expiration. Data is also encrypted. Customer data in Microsoft cloud services exists in two states: • at rest on storage media; and • in transit from a datacenter over a network to a customer device. Microsoft offers a range of built-in encryption capabilities to help protect data at rest. • For Office 365, Microsoft follows industry cryptographic standards such as TLS/SSL and AES to protect the confidentiality and integrity of customer data. For data in transit, all customer-facing servers negotiate a secure session by using TLS/SSL with client machines to secure the customer data. For data at rest, Office 365

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
29	Does the outsourcing agreement provide for data and system security requirements within the outsourcing agreement and does the financial institution monitor compliance with these requirements on an ongoing basis?	deploys BitLocker with AES 256-bit encryption on servers that hold all messaging data, including email and IM conversations, as well as content stored in SharePoint Online and OneDrive for Business. Additionally, in some scenarios, Microsoft uses file- level encryption. For Azure, technological safeguards such as encrypted communications and operational processes help keep customers' data secure. Microsoft also provides customers the flexibility to implement additional encryption and manage their own keys. For data in transit, Azure uses industry-standard secure transport protocols, such as TLS/SSL, between user devices and Microsoft datacenters. For data at rest, Azure offers many encryption options, such as support for AES-256, giving customers the flexibility to choose the data storage scenario that best meets the customer's needs. Such policies and procedures are available through Microsoft's online resources, including Microsoft Compliance, the Trust Center and the Service Trust Platform.
30	Does the outsourcing agreement include arrangements for the possibility and modalities of a sub-outsourcing, which ensure continuing compliance of the financial institution with regulatory requirements? (continued)	AT 9 No. 7 lit. g) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall include rules covering the possibility and modalities of subcontracting which ensure that the financial institution continues to comply with the prudential supervisory requirements. AT 9 No. 8 MaRisk With respect to subcontracting, where possible, either the outsourcing financial institution shall be given the right to reserve approval or concrete provisions shall be agreed in the outsourcing agreement specifying when individual work and process steps may be subcontracted. At the very least, it shall be contractually ensured that the agreements the external service provider has with subcontractors are consistent with the contractual arrangements of the original outsourcing agreement. In addition, the contractual requirements shall include in case of subcontracting an obligation on the part of the external service provider to provide information to the outsourcing financial institution. In the event that the external service provider subcontracts activities or processes to a third party, it shall remain responsible for reporting to the outsourcing institution.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
30	Does the outsourcing agreement include arrangements for the possibility and modalities of a sub-outsourcing, which ensure continuing compliance of the financial institution with regulatory requirements?	Microsoft commits that its subcontractors will be permitted to obtain customer data only to deliver the services Microsoft has retained them to provide and will be prohibited from using customer data for any other purpose. Microsoft remains responsible for its subcontractors' compliance with Microsoft's obligations in the Product Terms. To ensure subcontractor accountability, Microsoft requires all of its vendors that handle customer personal information to join the Microsoft Supplier Security and Privacy Assurance Program, which is an initiative designed to standardise and strengthen the handling of customer personal information, and to bring vendor business processes and systems into compliance with those of Microsoft. For more information regarding Microsoft's Supplier Security and Privacy Program, see https://www.microsoft.com/en-us/procurement/msp-requirements.aspx. Microsoft will enter into a written agreement with any subcontractor to which Microsoft transfers customer data that is no less protective than the Data Protection Addendum in the customer's contracts with Microsoft. In addition, Microsoft's ISO/IEC 27018 certification requires Microsoft to ensure that its subcontractors are subject to the same security controls as Microsoft. Microsoft's ISO 27001 certification provides a layer of additional controls that impose stringent requirements on Microsoft's subcontractors to comply fully with Microsoft's privacy, security, and other commitments to its customers, including requirements for handling sensitive data, background checks, and non-disclosure agreements. Microsoft provides a website that lists subcontractors authorised to access customer data in the Online Services as well as the limited or ancillary services they provide. At least 6 months before authorising any new subcontractor to access Customer Data, Microsoft will update the website and provide the customer with a mechanism to obtain notice of that update. If the customer does not approve of a new subcontractor, then the customer may terminate the affected Online Service without penalty by providing, before the end of the notice period, written notice of termination that includes an explanation of the grounds for non-approval. If the affected cloud computing service is part of a suite (or similar single purchase of services), then any termination will apply to the entire suite. After termination, Microsoft will remove payment obligations for the terminated Online Services from subsequent customer invoices.

REF.	QUESTION / REQUIREMENT	GUIDANCE
31	Does the outsourcing agreement include termination rights of the financial institution and are the termination periods appropriate? Does this include a termination right if such termination is requested by the regulator?	Paragraph 98 EBA Outsourcing Guidelines The outsourcing arrangement should expressly allow the possibility for financial institution to terminate the arrangement, in accordance with applicable law, including where (a) the provider of the outsourced functions is in a breach of applicable law, regulations or contractual provisions; (b) impediments capable of altering the performance of the outsourced function are identified; (c) where there are material changes affecting the outsourcing arrangement or the service provider (e.g. sub-outsourcing or changes of sub-contractors); (d) there are weaknesses regarding the management and security of confidential, personal or otherwise sensitive data or information; and (e) instructions are given by the financial institution's competent authority, e.g. in the case that the competent authority is, caused by the outsourcing arrangement, no longer in a position to effectively supervise the financial institution. AT 9 No. 7 lit. f) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall specify termination rights and appropriate notice periods. Sec. V. 6 of the BaFin Guidance Termination rights and adequate termination notice periods are to be agreed. In particular, a special termination right, providing for termination for good cause if the supervisory authority calls for the agreement to be ended, should be agreed. Microsoft agreements are usually subject to terms of 12-36 months, which may be extended at the customer's election. They also include rights to terminate early for cause and without cause. Microsoft's Financial Services Amendment provides for business continuity and exit provisions, including rights for the customer to obtain exit assistance at market rates from Microsoft Consulting Services. Customers should work with Microsoft to build such business continuity and exit plans. Microsoft's flexibility in offering hybrid solutions further facilitate transition from cloud to on-premise solutions more seamlessly.

REF.	QUESTION / REQUIREMENT	GUIDANCE
32	Does the outsourcing agreement also include reporting mechanisms that ensure that the financial institution is informed about developments which might negatively affect outsourced activities or processes?	AT 9 No. 7 lit. h) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall obligate the external service provider to inform the financial institution of any developments that might impair the proper performance of the outsourced activities and processes. Sec. V. 8 of the BaFin Guidance Provisions are to be agreed ensuring that the cloud service provider informs the financial institution about developments that might adversely affect the orderly performance of the outsourced items. That includes things like reporting any disruptions in providing the cloud service. This is to ensure that the company can adequately monitor the outsourced item. Microsoft provides access to “service health” dashboards (Office 365 Service Health Dashboard and Azure Status Dashboard) providing real-time and continuous updates on the status of Microsoft Online Services. This provides our IT administrators with information about the current availability of each service or tool (and history of availability status), details about service disruption or outage and scheduled maintenance times. The information is provided online and via an RSS feed.

REF.	QUESTION / REQUIREMENT	GUIDANCE
33	In the event of termination, do transitional arrangements address access to, and ownership of, documents, records, software and hardware, and the role of the service provider in transitioning the service? (continued)	Paragraph 99 EBA Outsourcing Guidelines The outsourcing arrangement should facilitate the transfer of the outsourced function to another service provider or its re-incorporation into the financial institution. To this end, the written outsourcing arrangement should: (a) clearly set out the obligations of the existing service provider, in the case of a transfer of the outsourced function to another service provider or back to the financial institution, including the treatment of data; (b) set an appropriate transition period, during which the service provider, after the termination of the outsourcing arrangement, would continue to provide the outsourced function to reduce the risk of disruptions; and (c) include an obligation of the service provider to support the financial institution in the orderly transfer of the function in the event of the termination of the outsourcing agreement. AT 9 No. 6 MaRisk In the case of material outsourced activities and processes, the financial institution, in the event of an intended or expected termination of the outsourcing arrangement, shall take safeguards to ensure the continuity and quality of the outsourced activities and processes also after the termination of the outsourcing arrangement. In cases of unintended or unexpected termination of these outsourced activities and processes that might seriously impair business activity, the financial institution shall examine the feasibility of and adopt possible courses of action. This shall entail, as far as meaningful and possible, defining corresponding exit processes. The courses of action shall be reviewed both regularly and on an ad hoc basis. Sec. V. 6 of the BaFin Guidance It has to be ensured that in the event of termination the items outsourced to the cloud service provider continue to be provided until such time that the outsourced item has been completely transferred to another cloud service provider or to the financial institution. In this regard it has to be guaranteed in particular that the cloud service provider will reasonably assist the financial institution in transferring the outsourced items to another cloud service provider or directly to the financial institution.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
33	In the event of termination, do transitional arrangements address access to, and ownership of, documents, records, software and hardware, and the role of the service provider in transitioning the service?	Yes. During the term of the agreement as well as upon expiration or termination, the customer can extract its data related to its use of the Online Services. As set out in the Product Terms, Microsoft will retain customer data stored in the Online Service in a limited function account for 90 days after expiration or termination of the customer's subscription so that the customer may extract the data. After the 90-day retention period ends, Microsoft will disable the customer's account and delete the customer data. Microsoft will disable the account and delete customer data from the account no more than 180 days after expiration or termination of customer's use of an Online Service. In the event of a termination and where a customer chooses to migrate to a different online service, customers may request that Microsoft provides assistance in such transition through Microsoft's Professional Services organization. Customers may also request migration or transition assistance and support from Microsoft's Professional Services organization at any time during the extended service period.

REF.	QUESTION / REQUIREMENT	GUIDANCE
E. TECHNICAL AND OPERATIONAL RISK Q&A Under various regulatory requirements, including its business continuity management and IT security risk requirements (which are not specific to outsourcing but should be considered nonetheless in the context of the outsourcing) financial institutions need to have in place appropriate measures to address IT risk, security risk, IT security risk and operational risk. This section provides some more detailed technical and operational information about Microsoft cloud services which should address many of the technical and operational questions that may arise. If other questions arise, please do not hesitate to get in touch with your Microsoft contact.		
34	Does the service provider permit audit by the financial institution and its competent authorities? (continued)	Paragraphs 85 to 97 EBA Outsourcing Guidelines and in particular: Paragraph 87 With regard to the outsourcing of critical or important functions, financial institutions should ensure within the written outsourcing agreement that the service provider grants them and their competent authorities, including resolution authorities, and any other person appointed by them or the competent authorities, the following: (a) full access to all relevant business premises (e.g. head offices and operation centres), including the full range of relevant devices, systems, networks, information and data used for providing the outsourced function, including related financial information, personnel and the service provider's external auditors ('access and information rights'); and (b) unrestricted rights of inspection and auditing related to the outsourcing arrangement ('audit rights'), to enable them to monitor the outsourcing arrangement and to ensure compliance with all applicable regulatory and contractual requirements. Article 31(2)(i) MOR the investment firm, its auditors and the relevant competent authorities [shall] have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider, where necessary for the purpose of effective oversight in accordance with this article, and the competent authorities are able to exercise those rights of access; Article 274(4)(h) SolReg the insurance or reinsurance undertaking, its external auditor and the supervisory authority have effective access to all information relating to the outsourced functions and activities including carrying out on-site

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
34	Does the service provider permit audit by the financial institution and its competent authorities?	inspections of the business premises of the service provider; AT 9 No. 7(b) and (c) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review and ensure that the competent authorities pursuant to section 25b (3) of the Banking Act retain unrestricted rights of information and review and the ability to supervise with regard to the outsourced activities and processes. Sec. V. 2 and 3 of the BaFin Guidance Information and audit rights as well as control possibilities of the financial institution and the supervisory authorities must not be subject to contractual restrictions. It has to be ensured that the financial institution receives the information it needs to adequately control and monitor the risks associated with the outsourcing. The supervisory authorities must be able to monitor cloud service providers exactly as the applicable law provides for the financial institution. Yes. The Financial Services Amendment provides customers and their auditors with the unrestricted rights of inspection and auditing related to the outsourcing arrangement, which includes specific rights of access to business premises for financial services customers via special contractual provisions designed for regulated customers in the financial services sector. Additionally, the Financial Services Amendment provides the customer's regulator to examine or audit the Online Services in order to meet the regulator's supervisory obligations of Microsoft as a direct service provider of the customer. These rights enable such customers to comply with their regulatory obligations through direct access to business premises, to information, Microsoft personnel and Microsoft's external auditor. Customers may also participate in the optional Compliance Program for the Microsoft Cloud to obtain additional information concerning the Online Services, including the following: (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.

REF.	QUESTION / REQUIREMENT	GUIDANCE
35	Are the service provider's services subject to any third-party audit? (continued)	Paragraph 87 EBA Outsourcing Guidelines With regard to the outsourcing of critical or important functions, financial institutions should ensure within the written outsourcing agreement that the service provider grants them and their competent authorities, including resolution authorities, and any other person appointed by them or the competent authorities, the following: (a) full access to all relevant business premises (e.g. head offices and operation centres), including the full range of relevant devices, systems, networks, information and data used for providing the outsourced function, including related financial information, personnel and the service provider's external auditors ('access and information rights'); and (b) unrestricted rights of inspection and auditing related to the outsourcing arrangement ('audit rights'), to enable them to monitor the outsourcing arrangement and to ensure compliance with all applicable regulatory and contractual requirements. Article 31(2)(i) MOR the investment firm, its auditors and the relevant competent authorities [shall] have effective access to data related to the outsourced functions, as well as to the relevant business premises of the service provider, where necessary for the purpose of effective oversight in accordance with this article, and the competent authorities are able to exercise those rights of access; Article 274(4)(h) SolReg the insurance or reinsurance undertaking, its external auditor and the supervisory authority have effective access to all information relating to the outsourced functions and activities including carrying out on-site inspections of the business premises of the service provider; AT 9 No. 7(b) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall set out appropriate internal and external auditors' rights of information and review. Sec. V. 2 of the BaFin Guidance Depending on the applicable requirements under supervisory law, the supervised companies may claim

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
35	Are the service provider's services subject to any third-party audit?	exemptions to make their own audit activities more efficient. Such exemptions are pooled audits or the use of documentation/certificates based on common standards or of audit reports of recognised third parties or of internal audit reports of the cloud service provider. Yes. Microsoft's cloud services are subject to regular independent third party audits, including SSAE16 SOC1 Type II, SSAE SOC2 Type II, ISO/IEC 27001, ISO/IEC 27002 and ISO/IEC 27018. Rigorous third-party audits, , validate the adherence of the Online Services to the strict requirements of these standards.
36	Where the service provider sub- outsources certain services, does the sub-contractor agree to (i) comply with all applicable laws, regulatory requirements and contractual obligations; and (ii) grant the financial institution and competent authority the same contractual rights of access and audit as those granted by the service provider? (continued)	Paragraph 79 EBA Outsourcing Guidelines Financial institutions should agree to sub-outsourcing only if the sub-contractor undertakes to: (a) comply with all applicable laws, regulatory requirements and contractual obligations; and (b) grant the financial institution and competent authority the same contractual rights of access and audit as those granted by the service provider. AT 9 No. 8 MaRisk It shall be contractually ensured that the agreements the external service provider has with subcontractors are consistent with the contractual arrangements of the original outsourcing agreement. Sec. V. 7 of the BaFin Guidance Provisions on the possibility and the modalities of chain-outsourcing ensuring that the requirements of supervisory law continue to be met are to be agreed. Restrictions resulting, e.g., in only the most substantially similar obligations being assumed are not permissible. It must be ensured in particular that the information and audit rights as well as controlling possibilities of the supervised outsourcing company as well as of the supervisory authorities also apply to subcontractors in the case of chain-outsourcing. Microsoft commits that its subcontractors are bound by written agreements that require them to provide at least the level of data protection required of Microsoft by the Data Protection Addendum, including the limitations on disclosure of Processed Data. Microsoft remains responsible for its subcontractors' compliance with Microsoft's obligations in the Product Terms. To ensure subcontractor accountability, Microsoft requires all of its vendors that handle customer personal information to join the Microsoft Supplier Security and Privacy Assurance Program, which is an initiative

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
36	Where the service provider sub- outsources certain services, does the sub- contractor agree to (i) comply with all applicable laws, regulatory requirements and contractual obligations; and (ii) grant the financial institution and competent authority the same contractual rights of access and audit as those granted by the service provider?	designed to standardise and strengthen the handling of customer personal information, and to bring vendor business processes and systems into compliance with those of Microsoft. For more information regarding Microsoft's Supplier Security and Privacy Program, see https://www.microsoft.com/en-us/procurement/msp-requirements.aspx. Microsoft will enter into a written agreement with any subcontractor that is no less protective than the Data Protection Addendum in the customer's contracts with Microsoft. In addition, Microsoft's ISO/IEC 27018 certification requires Microsoft to ensure that its subcontractors are subject to the same security controls as Microsoft. Microsoft's ISO 27001 certification provides a layer of additional controls that impose stringent requirements on Microsoft's subcontractors to comply fully with Microsoft's privacy, security, and other commitments to its customers, including requirements for handling sensitive data, background checks, and non-disclosure agreements. Microsoft commits that Regulator and Customer rights of audit will include, as necessary, the audit of sub-contractors that perform and process operations of the Online Services

REF.	QUESTION / REQUIREMENT	GUIDANCE
37	Does the outsourcing agreement provide instruction rights of the financial institution with regard to the correction, deletion and blocking of data? Does it include a provision pursuant to which the service provider may only collect, process or use the data within the framework of the instructions issued by the financial institution? Is there the possibility of issuing instructions at any time for the immediate and unrestricted return of the data processed by service provider to the financial institution?	Sec. V. 4 of the BaFin Guidance The financial institution should be authorised at all times to issue instructions to the cloud service provider for correction, deletion and blocking of data and the cloud service provider should be allowed to collect, process and use the data only in the context of the instructions issued by the financial institution. This should also cover the possibility of issuing an instruction at any time to have the data processed by the cloud service provider transferred back to the financial institution promptly and without restriction. The terms and conditions of the agreement with Microsoft provide for return of the data to the customer. Above all, as stipulated under the Product Terms, such data remains at all times the property of the customer, which is always entitled to access and extract its data. Microsoft retains customer data stored in the Online Service in a limited function account for 90 days after expiration or termination of the customer's subscription so that it may extract the data. Additionally, the Financial Services Amendment provides an option to extend the customer's use of the Online Services by monthly increments, should it become necessary to prepare for an exit from the services. As set out in the Product Terms, Microsoft will retain customer data stored in the Online Service in a limited function account for 90 days after expiration or termination of the customer's subscription so that the customer may extract the data. After the 90-day retention period ends, Microsoft will disable the customer's account and delete the customer data. Microsoft will disable the account and delete customer data from the account no more than 180 days after expiration or termination of customer's use of an Online Service.

REF.	QUESTION / REQUIREMENT	GUIDANCE
38	Does the financial institution agree to sub-outsourcing critical or important functions? (continued)	Paragraph 76 EBA Outsourcing Guidelines The outsourcing agreement should specify whether or not sub-outsourcing of critical or important functions, or material parts thereof, is permitted. Paragraph 77 EBA Outsourcing Guidelines If sub-outsourcing of critical or important functions is permitted, institutions and payment institutions should determine whether the part of the function to be sub-outsourced is, as such, critical or important (i.e. a material part of the critical or important function) and, if so, record it in the register. Article 31(3) MOR The agreement shall ensure that outsourcing by the service provider only takes place with the consent, in writing, of the investment firm. Article 274(4)(k) SolReg The written agreement shall in particular clearly state the terms and conditions, where applicable, under which the service provider may sub-outsource any of the outsourced functions and activities; AT 9 No. 11 MaRisk The requirements governing the outsourcing of activities and processes shall be complied with also in the event that the outsourced activities and processes are subcontracted. Sec. V. 7 of the BaFin Guidance Provisions on the possibility and the modalities of chain-outsourcing ensuring that the requirements of supervisory law continue to be met are to be agreed. Restrictions resulting, e.g., in only the most substantially similar obligations being assumed are not permissible. It must be ensured in particular that the information and audit rights as well as controlling possibilities of the outsourcing financial institution as well as of the supervisory authorities also apply to subcontractors in the case of chain-outsourcing. Microsoft commits that Regulator and Customer rights of audit will include, as necessary, the audit of sub-contractors that perform and process operations of the Online Services. At the time of entering into a cloud outsourcing agreement the customer has access to a list of identified subprocessors a <u>website</u> that lists subcontractors authorised to access

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
38	Does the financial institution agree to sub-outsourcing critical or important functions?	customer data in the Online Services as well as the limited or ancillary services they provide. At least 6 months before authorising any new subcontractor to access Customer Data, Microsoft will update the website and provide the customer with a mechanism to obtain notice of that update. If the customer does not approve of a new subcontractor, then the customer may terminate the affected Online Service without penalty by providing, before the end of the notice period, written notice of termination that includes an explanation of the grounds for non-approval. If the affected cloud computing service is part of a suite (or similar single purchase of services), then any termination will apply to the entire suite. After termination, Microsoft will remove payment obligations for the terminated Online Services from subsequent customer invoices.
39	How is the financial institution's data isolated from other data held by the service provider?	For all of its Online Services, Microsoft logically isolates customer data from the other data Microsoft holds. Data storage and processing for each tenant is segregated through an "Active Directory" structure, which isolates customers using security boundaries ("silos"). The silos safeguard the customer's data such that the data cannot be accessed or compromised by co-tenants. Microsoft further describes its practice of logical isolation of data here .
40	How are the service provider's access logs monitored?	Microsoft provides monitoring and logging technologies to give its customers maximum visibility into the activity on their cloud-based network, applications, and devices, so they can identify potential security gaps. The Online Services contain features that enable customers to restrict and monitor their employees' access to the services, including the Azure AD Privileged Identify Management system and Multi-Factor Authentication. In addition, the Online Services include built-in approved Windows PowerShell Scripts, which minimise the access rights needed and the surface area available for misconfiguration. Microsoft logs, or enables customers to log, access and use of information systems containing customer data, registering the access ID, time, authorisation granted or denied, and relevant activity. An internal, independent Microsoft team audits the log at least once per quarter, and customers have access to such audit logs. In addition, Microsoft periodically reviews access levels to ensure that only users with appropriate business justification have access to appropriate systems.

REF.	QUESTION / REQUIREMENT	GUIDANCE
41	What policies does the service provider have in place to monitor employees with access to confidential information?	For certain core services of Office 365 and Azure, personnel (including employees and subcontractors) with access to customer data content are subject to background screening, security training, and access approvals as allowed by applicable law. Background screening takes place before Microsoft authorises the employee to access customer data. To the extent permitted by law, any criminal history involving dishonesty, breach of trust, money laundering, or job-related material misrepresentation, falsification, or omission of fact may disqualify a candidate from employment, or, if the individual has commenced employment, may result in termination of employment at a later day. Authorization may also be done via <u>role-based access controls</u> ("RBAC") or through Key Vault access policy. RBAC is an access management tool that allows the cloud customer to manage who has access to Azure resources, what those with access can do with those resources, and what areas they have access to. RBAC enables the customer to create role assignments and define each of those assignments with differing levels of access and control. The customer may also secure its Azure management ports with <u>just-in-time access controls</u> that reduce exposure to cyber-attacks.
42	How are users authenticated?	Microsoft cloud services use two-factor authentication to enhance security. Typical authentication practices that require only a password to access resources may not provide the appropriate level of protection for information that is sensitive or vulnerable. Two-factor authentication is an authentication method that applies a stronger means of identifying the user. The Microsoft phone-based two-factor authentication solution allows users to receive their PINs sent as messages to their phones, and then they enter their PINs as a second password to log on to their services. Authentication is done via Azure Active Directory. Authorization may be done via role-based access controls ("RBAC") or Key Vault access policy. RBAC is an access management tool that allows the cloud customer to manage who has access to Azure resources, what those with access can do with those resources, and what areas they have access to. RBAC enables the cloud customer to create role assignments and define each of those assignments with differing levels of access and control. It is used when dealing with the management of the vaults and Key Vault access policy is used when attempting to access data stored in a vault.

REF.	QUESTION / REQUIREMENT	GUIDANCE
F. PRIVACY AND IT SECURITY SAFEGUARDS Under various EBA requirements, including its business continuity management and IT security risk requirements, financial institutions need to have in place appropriate measures to address IT risk, security risk, IT security risk, privacy issues and requirements, and operational risk. This section provides some more detailed technical and operational information about Microsoft cloud services which should address many of the technical and operational questions that may arise. If other questions arise, please do not hesitate to get in touch with your Microsoft contact.		
43	Will use of the cloud service enable the financial institution to continue complying with the EU Privacy (Data Protection) Principles? (continued)	Paragraph 34 EBA Outsourcing Guidelines Financial institutions should ensure that they comply with all requirements under GDPR, including for their third-party and outsourcing arrangements. AT 9 No. 7(e) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall include rules ensuring compliance with data protection provisions and other security requirements. Sec. V. 5 of the BaFin Guidance Provisions ensuring compliance with data protection regulations and other security requirements are to be agreed. Microsoft is committed to protect the privacy of its customers and is constantly working to help strengthen privacy and compliance protections for its customers. Not only does Microsoft have robust and industry leading security practices in place to protect its customers' data and robust data protection clauses included, as standard, in its Product Terms, Microsoft has gone further. Notably, Microsoft has taken two important and industry first steps to prove its commitment to privacy. First, in April 2014, the EU's 28 data protection authorities acted through their "Article 29 Working Party" to approve that Microsoft's contractual commitments meet the requirements of the EU's "model clauses". Europe's privacy regulators have said, in effect, that personal data stored in Microsoft's enterprise cloud is subject to Europe's rigorous privacy standards no matter where that data is located.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
43	Will use of the cloud service enable the financial institution to continue complying with the EU Privacy (Data Protection) Principles?	Second, in February 2015, Microsoft became the first major cloud provider to adopt the world's first international standard for cloud privacy, ISO/IEC 27018. The standard was developed by the International Organization for Standardization (ISO) to establish a uniform, international approach to protecting privacy for personal data stored in the cloud. The British Standards Institute (BSI) has now independently verified that Microsoft is aligned with the standard's code of practice for the protection of Personally Identifiable Information (PII) in the public cloud. We are committed to making sure that our products and services comply with GDPR. See Microsoft's commitment to GDPR, privacy and putting customers in control of their own data - Microsoft On the Issues and have also made the changes required following the Schrems II judgment of the Court of Justice of the European Union on July 16, 2020. Learn more at Microsoft Data Privacy Principles Microsoft Trust Center.
44	How is end-to-end application encryption security implemented to protect PINs and other sensitive data transmitted between terminals and hosts? (continued)	Paragraph 68(e) EBA Outsourcing Guidelines Financial institutions should define and decide on an appropriate level of protection of data confidentiality, or continuity of the activities outsourced and of the integrity and traceability of data in systems in the context of the intended outsourcing. Financial institutions should also consider specific measures, where necessary, for data in transit, data in memory and data at rest, such as the use of encryption technologies in combination with an appropriate key management architecture; There are three key aspects to Microsoft's encryption: 1. Secure identity: Identity (of a user, computer, or both) is a key element in many encryption technologies. For example, in public key (asymmetric) cryptography, a key pair—consisting of a public and a private key—is issued to each user. Because only the owner of the key pair has access to the private key, the use of that key identifies the associated owner as a party to the encryption/decryption process. Microsoft Public Key Infrastructure is based on certificates that verify the identity of users and computers 2. Secure infrastructure: Microsoft uses multiple encryption methods, protocols, and algorithms across its products and services to help provide a secure path for data to travel through the infrastructure, and to help protect the confidentiality of data that is stored within the infrastructure. Microsoft uses some of the strongest, most secure

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
44	How is end-to-end application encryption security implemented to protect PINs and other sensitive data transmitted between terminals and hosts?	encryption protocols in the industry to provide a barrier against unauthorised access to our data. Proper key management is an essential element in encryption best practices, and Microsoft helps ensure that encryption keys are properly secured. Protocols and technologies examples include: a. Transport Layer Security (TLS), which uses symmetric cryptography based on a shared secret to encrypt communications as they travel over the network. b. Internet Protocol Security (IPsec), an industry-standard set of protocols used to provide authentication, integrity, and confidentiality of data at the IP packet level as it's transferred across the network. c. Office 365 servers using BitLocker to encrypt the disk drives containing log files and customer data at rest at the volume-level. BitLocker encryption is a data protection feature built into Windows to safeguard against threats caused by lapses in controls (e.g., access control or recycling of hardware) that could lead to someone gaining physical access to disks containing customer data. d. BitLocker deployed with Advanced Encryption Standard (AES) 256-bit encryption on disks containing customer data in Exchange Online, SharePoint Online, and Skype for Business. Advanced Encryption Standard (AES)-256 is the National Institute of Standards and Technology (NIST) specification for a symmetric key data encryption that was adopted by the US government to replace Data Encryption Standard (DES) and RSA 2048 public key encryption technology. e. BitLocker encryption that uses AES to encrypt entire volumes on Windows server and client machines, which can be used to encrypt Hyper-V virtual machines when a virtual Trusted Platform Module (TPM) is added. BitLocker also encrypts Shielded VMs in Windows Server 2016, to ensure that fabric administrators cannot access the information inside the virtual machine. The Shielded VMs solution includes the Host Guardian Service feature, which is used for virtualization host attestation and encryption key release. 3. Secure apps and data: Information concerning security and encryption of Microsoft cloud services may be found at microsoft.com/en-us/trustcenter/security/encryption. Further information concerning Microsoft controls and applicable SOC audit reports may be found at: Service Organization Controls (SOC) - Microsoft Compliance Microsoft Docs

REF.	QUESTION / REQUIREMENT	GUIDANCE
45	Does the service provider agree to protect confidential, personal or otherwise sensitive information and comply with all legal requirements regarding the protection of data that apply to the financial institution?	Paragraph 84 EBA Outsourcing Guidelines Without prejudice to the requirements under the GDPR, financial institutions, when outsourcing (in particular to third countries), should take into account differences in national provisions regarding the protection of data. Financial institutions should ensure that the outsourcing agreement includes the obligation that the service provider protects confidential, personal or otherwise sensitive information and complies with all legal requirements regarding the protection of data that apply to the financial institution (e.g. the protection of personal data and that banking secrecy or similar legal confidentiality duties with respect to clients' information, where applicable, are observed). Article 31(2)(j) MOR Investment firms shall take the necessary steps to ensure the service provider protects any confidential information relating to the investment firm and its clients. Article 274(3)(e) SolReg The administrative, management or supervisory body shall ensure that the outsourcing does not entail the breaching of any law in particular with regard to rules on data protection AT 9 No. 7 lit. e) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall include rules ensuring compliance with data protection provisions. Sec. V. 5 of the BaFin Guidance Provisions ensuring compliance with data protection regulations and other security requirements are to be agreed. Yes. Microsoft will comply with all privacy and data protection laws applicable to it in the provision of the Online Services. For information on how Microsoft handles your data in the cloud, refer to the <u>Subprocessor and Data Privacy White Paper</u>. Microsoft will not disclose confidential information (which includes customer data) to third parties (unless required by law) and will only use confidential information for the purposes of Microsoft's business relationship with the customer. In addition, Microsoft will ensure that its personnel engaged in the processing of customer and personal data will be obliged to maintain the confidentiality and security of such data even after their engagement ends.

REF.	QUESTION / REQUIREMENT	GUIDANCE
46	What security controls are in place to protect the transmission and storage of confidential information such as customer data within the infrastructure of the service provider? (continued)	Paragraph 82 EBA Outsourcing Guidelines Where relevant (e.g. in the context of cloud or other ICT outsourcing), financial institutions should define data and system security requirements within the outsourcing agreement and monitor compliance with these requirements on an ongoing basis. Paragraph 83 EBA Outsourcing Guidelines In the case of outsourcing to cloud service providers and other outsourcing arrangements that involve the handling or transfer of personal or confidential data, financial institutions should adopt a risk-based approach to data storage and data processing location(s) (i.e. country or region) and information security considerations. Article 274(3)(f)) SolReg The administrative, management or supervisory body shall ensure that the service provider is subject to the same provisions on the safety and confidentiality of information relating to the insurance or reinsurance undertaking or to its policyholders or beneficiaries that are applicable to the insurance or reinsurance undertaking. The Microsoft cloud services security features consist of three parts: (a) built-in security features; (b) security controls; and (c) scalable security. These include 24-hour monitored physical hardware, isolated customer data, automated operations and lock-box processes, secure networks and encrypted data. Microsoft implements the Microsoft Security Development Lifecycle (SDL) which is a comprehensive security process that informs every stage of design, development and deployment of Microsoft cloud services. Through design requirements, analysis of attack surface and threat modelling, the SDL helps Microsoft predict, identify and mitigate vulnerabilities and threats from before a service is launched through its entire production lifecycle. Networks within Microsoft's datacenters are segmented to provide physical separation of critical back-end servers and storage devices from the public-facing interfaces. Edge router security allows the ability to detect intrusions and signs of vulnerability. Customer access to services provided over the Internet originates from users' Internet-enabled locations and ends at a Microsoft datacenter. These connections are encrypted using industry-standard transport layer security TLS.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
46	What security controls are in place to protect the transmission and storage of confidential information such as customer data within the infrastructure of the service provider? (continued)	The use of TLS establishes a highly secure client-to-server connection to help provide data confidentiality and integrity between the desktop and the datacenter. Customers can configure TLS between Microsoft cloud services and external servers for both inbound and outbound email. This feature is enabled by default. Microsoft also implements traffic throttling to prevent denial-of-service attacks. It uses the “prevent, detect and mitigate breach” process as a defensive strategy to predict and prevent security breaches before they happen. This involves continuous improvements to built-in security features, including port-scanning and remediation, perimeter vulnerability scanning, OS patching to the latest updated security software, network-level DDOS detection and prevention and multi-factor authentication for service access. Use of a strong password is enforced as mandatory, and the password must be changed on a regular basis. From a people and process standpoint, preventing breach involves auditing all operator/ administrator access and actions, zero standing permission for administrators in the service, “Just-In-Time (JIT) access and elevation” (that is, elevation is granted on an as-needed and only-at-the-time-of-need basis) of engineer privileges to troubleshoot the service, and isolation of the employee email environment from the production access environment. Employees who have not passed background checks are automatically rejected from high privilege access, and checking employee backgrounds is a highly scrutinized, manual- approval process. Preventing breach also involves automatically deleting unnecessary accounts when an employee leaves, changes groups, or does not use the account prior to its expiration. Data is also encrypted. Customer data in Microsoft cloud services exists in two states: • at rest on storage media; and • in transit from a datacenter over a network to a customer device. Microsoft offers a range of built-in encryption capabilities to help protect data at rest. • For Office 365, Microsoft follows industry cryptographic standards such as TLS/SSL and AES to protect the confidentiality and integrity of customer data. For data in transit, all customer-facing servers negotiate a secure session by using TLS/SSL with client machines to secure the customer data. For data at rest, Office 365 deploys BitLocker with AES 256-bit encryption on servers that hold all messaging data, including email and IM conversations, as well as content stored in SharePoint Online and OneDrive for Business. Additionally, in some scenarios, Microsoft uses file- level encryption.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
46	What security controls are in place to protect the transmission and storage of confidential information such as customer data within the infrastructure of the service provider?	For Azure, technological safeguards such as encrypted communications and operational processes help keep customers' data secure. Microsoft also provides customers the flexibility to implement additional encryption and manage their own keys. For data in transit, Azure uses industry-standard secure transport protocols, such as TLS/SSL, between user devices and Microsoft datacenters. For data at rest, Azure offers many encryption options, such as support for AES-256, giving customers the flexibility to choose the data storage scenario that best meets the customer's needs. Such policies and procedures are available through Microsoft's online resources, including Microsoft Compliance, the Trust Center and the Service Trust Platform.
47	How is the financial institution assessing the potential impact of outsourcing arrangements on their operational risk? (continued)	Paragraphs 64 and 65 EBA Outsourcing Guidelines and in particular Paragraph 65 The assessment should include, where appropriate, scenarios of possible risk events, including high-severity operational risk events. Within the scenario analysis, institutions and payment institutions should assess the potential impact of failed or inadequate services, including the risks caused by processes, systems, people or external events. Financial institutions, taking into account the principle of proportionality, should document the analysis performed and their results and should estimate the extent to which the outsourcing arrangement would increase or decrease their operational risk. Sec. IV. of the BaFin Guidance In the risk analysis, an assessment of the financial risks, operational risks (e.g. system failure, sabotage), including the legal risks (e.g. risks of legal enforcement, risks of data protection law) as well as reputational risks should be carried out; these also include consideration regarding data storage and data processing locations shall be considered.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
47	How is the financial institution assessing the potential impact of outsourcing arrangements on their operational risk?	Microsoft provides access to “service health” dashboards (Office 365 Service Health Dashboard and Azure Status Dashboard) providing real-time and continuous updates on the status of Microsoft Online Services. This provides your IT administrators with information about the current availability of each service or tool (and history of availability status), details about service disruption or outage and scheduled maintenance times. The information is provided online and via an RSS feed. As part of its certification requirements, Microsoft is required to undergo independent third-party auditing, and it shares with the customer the independent third party audit reports. Microsoft also makes available a wealth of resources online to provide transparency and assurance to customers in the Microsoft compliance documentation dashboard.
48	How is the financial institution assessing the effectiveness of implemented IT security measures and processes? (continued)	Paragraph 94 EBA Outsourcing Guidelines Financial institutions should, where relevant, ensure that they are able to carry out security penetration testing to assess the effectiveness of implemented cyber and internal information and communication technology (ICT) security measures and processes. Payment institutions should also have internal ICT control mechanisms, including ICT security control and mitigation measures. First, there are robust procedures offered by Microsoft that enable the prevention of security incidents and violations arising in the first place and detection if they do occur. Specifically: a. Microsoft implements 24 hour monitored physical hardware. Datacenter access is restricted 24 hours per day by job function so that only essential personnel have access to customer applications and services. Physical access control uses multiple authentication and security processes, including badges and smart cards, biometric scanners, on-premises security officers, continuous video surveillance, and two-factor authentication. b. Microsoft implements “prevent, detect, and mitigate breach”, which is a defensive strategy aimed at predicting and preventing a security breach before it happens. This involves continuous improvements to built-in security features, including port scanning and remediation, perimeter vulnerability scanning, OS patching to the latest updated security software, network-level DDOS (distributed denial-of-service) detection and prevention, and multi-factor authentication for service access. In addition, Microsoft has anti-malware controls to help avoid malicious software

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
48	How is the financial institution assessing the effectiveness of implemented IT security measures and processes? (continued)	from gaining unauthorised access to customer data. Microsoft implements traffic throttling to prevent denial-of-service attacks, and maintains a set of Security Rules for managed code to help ensure that application cybersecurity threats are detected and mitigated before the code is deployed. c. Microsoft employs some of the world’s top experts in cybersecurity, cloud compliance, and financial services regulation. Its Digital Crimes Unit, for example, employs cyber experts, many of whom previously worked for law enforcement, to use the most advanced tools to detect, protect, and respond to cybercriminals. Its Cyber Defense Operations Center brings together security response experts from across Microsoft to help protect, detect, and respond 24/7 to security threats against Microsoft’s infrastructure and Online Services in real-time. General information on cybersecurity can be found here. d. Microsoft conducts a risk assessment for the Online Services at least annually to identify internal and external threats and associated vulnerabilities in their respective environments. Information is gathered from numerous data sources within Microsoft through interviews, workshops, documentation review, and analysis of empirical data. The assessment follows a documented process to produce consistent, valid, and comparable results year over year. e. Wherever possible, human intervention is replaced by an automated, tool-based process, including routine functions such as deployment, debugging, diagnostic collection, and restarting services. Microsoft continues to invest in systems automation that helps identify abnormal and suspicious behaviour and respond quickly to mitigate security risk. Microsoft is continuously developing a highly effective system of automated patch deployment that generates and deploys solutions to problems identified by the monitoring systems—all without human intervention. This greatly enhances the security and agility of the service. f. Microsoft allows customers to monitor security threats on their server by providing access to the Azure Security Center, Office 365 Advanced Threat Analytics, Azure Status Dashboard, and the Office 365 Service Health Dashboard, among other online resources. g. Microsoft maintains 24-hour monitoring of its Online Services and records all security breaches. For security breaches resulting in unlawful or unauthorised access to Microsoft’s equipment, facilities, or customer data, Microsoft notifies affected parties without unreasonable delay. Microsoft conducts a thorough review of all information security incidents.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
48	How is the financial institution assessing the effectiveness of implemented IT security measures and processes? (continued)	h. Microsoft conducts penetration tests to enable continuous improvement of incident response procedures. These internal tests help Microsoft cloud services security experts create a methodical, repeatable, and optimised stepwise response process and automation. In addition, Microsoft provides customers with the ability to conduct their own penetration testing of the services. This is done in accordance with Microsoft's rules of engagement, which do not require Microsoft's permission in advance of such testing. Second, if a security incident or violation is detected, Microsoft Customer Service and Support notifies customers by updating the Service Health Dashboard. Customers would have access to Microsoft's dedicated support staff, who have a deep knowledge of the service. Microsoft provides Recovery Time Objective (RTO) commitments. These differ depending on the applicable Microsoft service and are outlined further below. Finally, after the incident, Microsoft provides a thorough post-incident review report (PIR). The PIR includes: • An incident summary and event timeline. • Broad customer impact and root cause analysis. • Actions being taken for continuous improvement. If the customer is affected by a service incident, Microsoft shares the post-incident review with them. Microsoft's commitment to cybersecurity and data privacy, including restrictions on access to customer data, are set forth in Microsoft's contracts with customers. In summary: • Logical Isolation. Microsoft logically isolates customer data from the other data Microsoft holds. This isolation safeguards customers' data such that the data cannot be accessed or compromised by co-tenants. • 24-Hour Monitoring & Review of Information Security Incidents. Microsoft maintains 24-hour monitoring of its Online Services and records all security breaches. Microsoft conducts a thorough review of all information security incidents. For security breaches resulting in unlawful or unauthorised access to Microsoft's equipment, facilities, or customer data, Microsoft notifies affected parties without unreasonable delay. For more information regarding Microsoft's security incident management, refer to https://docs.microsoft.com/en-us/compliance/assurance/assurance-security-incident-management; http://aka.ms/SecurityResponsepaper.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
48	How is the financial institution assessing the effectiveness of implemented IT security measures and processes?	• Minimising Service Disruptions—Redundancy. Microsoft makes every effort to minimise service disruptions, including by implementing physical redundancies at the disk, Network Interface Card (“NIC”), power supply, and server levels; constant content replication; robust backup, restoration, and failover capabilities; and real-time issue detection and automated response such that workloads can be moved off any failing infrastructure components with no perceptible impact on the service. • Resiliency. Microsoft Online Services offer active load balancing, automated failover and human backup, and recovery testing across failure domains. • Distributed Services. Microsoft offers distributed component services to limit the scope and impact of any failures of a single component, and directory data is replicated across component services to insulate one service from another in the event of a failure. • Simplification. Microsoft uses standardised hardware to reduce issue isolation complexities. Microsoft also uses fully automated deployment models and a standard built-in management mechanism. • Human Backup. Microsoft Online Services include automated recovery actions with 24/7 on-call support; a team with diverse skills on call to provide rapid response and resolution; and continuous improvement through learning from the on-call teams. • Disaster Recovery Tests. Microsoft conducts disaster recovery tests at least once per year. Customers also have access to the Azure Security Center, Office 365 Advanced Threat Analytics, Azure Status Dashboard, and the Office 365 Service Health Dashboard, among other online resources, which allow customers to monitor security threats on the cloud service provider’s server.

REF.	QUESTION / REQUIREMENT	GUIDANCE
49	Are there procedures established to securely destroy or remove the data when the need arises (for example, when the contract terminates)?	Paragraph 107(b) EBA Outsourcing Guidelines Financial institutions shall identify alternative solutions and develop transition plans to be able to remove outsourced functions and data from the service provider and transfer them to alternative providers or back to the financial institution or to take other measures that ensure the continuous provision of the critical or important function or business activity in a controlled and sufficiently tested manner, taking into account the challenges that may arise because of the location of data and taking the necessary measures to ensure business continuity during the transition phase. Sec. V. 6 of the BaFin Guidance It should be agreed that after re-transfer of the data to the financial institution its data have been completely and irrevocably deleted on the side of the cloud service provider. Yes. Microsoft uses best practice procedures and a wiping solution that is NIST 800-88, ISO/IEC 27001, ISO/IEC 27018, SOC1 and SOC2 compliant. For hard drives that cannot be wiped it uses a destruction process that destroys it (i.e. shredding) and renders the recovery of information impossible (e.g., disintegrate, shred, pulverize, or incinerate). The appropriate means of disposal is determined by the asset type. Records of the destruction are retained. Information regarding SOC reports is available here: Service Organization Controls (SOC) - Microsoft Compliance Microsoft Docs. Audit reports for Microsoft services are available here: MSComplianceGuideV3 (microsoft.com) All Microsoft online services utilise approved media storage and disposal management services. Paper documents are destroyed by approved means at the pre-determined end-of-life cycle. In its contracts with customers, Microsoft commits to disabling a customer's account and deleting customer data from the account no more than 180 days after the expiration or termination of the Online Service. "Secure disposal or re-use of equipment and disposal of media" is covered under the ISO/IEC 27001 standards against which Microsoft is certified.

REF.	QUESTION / REQUIREMENT	GUIDANCE
50	Are there documented security procedures for safeguarding hardware, software and data in the datacenter?	Yes. These are described at length in the Microsoft Trust Center at microsoft.com/trust. For information on: • design and operational security see https://www.microsoft.com/en-us/security/business/operations • network security see https://www.microsoft.com/en-us/security/business/operations • encryption see https://www.microsoft.com/en-us/security/business/operations • threat management see https://www.microsoft.com/en-us/security/business/operations • identify and access management see https://www.microsoft.com/en-us/trustcenter/security/identity
51	Does the financial institution have a disaster recovery or business continuity plan with regard to outsourced critical or important functions? (continued)	Paragraph 48 EBA Outsourcing Guidelines Financial institutions should have in place, maintain and periodically test appropriate business continuity plans with regard to outsourced critical or important functions. Institutions and payment institutions within a group or institutional protection scheme may rely on centrally established business continuity plans regarding their outsourced functions. Article 31(2)(k) MOR Investment firms shall take the necessary steps to ensure the investment firm and the service provider have established, implemented and maintained a contingency plan for disaster recovery and periodic testing of backup facilities, where that is necessary having regard to the function, service or activity that has been outsourced. Article 31(2)(l) MOR The investment firm must ensure that the continuity and quality of the outsourced functions or services are maintained also in the event of termination of the outsourcing either by transferring the outsourced functions or services to another third party or by performing them itself.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
51	Does the financial institution have a disaster recovery or business continuity plan with regard to outsourced critical or important functions?	Article 274(5)(b) SolReg The insurance or reinsurance undertaking that is outsourcing critical or important operational functions or activities shall adequately take account of the outsourced activities in its risk management and internal control systems to ensure compliance with SolDir. Article 274(5)(d) SolReg The insurance or reinsurance undertaking must ensure that the service provider has adequate contingency plans in place to deal with emergency situations or business disruptions and periodically tests backup facilities where necessary, taking into account the outsourced functions and activities. Yes. Microsoft works with its customers to develop exit strategies and exit plans and Microsoft's best practices, informed by the EBA, direct that Microsoft coordinate with the financial institution in the event of an exit from the cloud environment. In addition to specific assistance, Microsoft provides guidance and examples of how exit plans could play out in execution. Microsoft's cloud services contracts with financial institutions provide numerous ways in which the cloud service provider relationship may be terminated, coupled with means of data retention and portability to a new cloud service provider or in a return to the financial institution's on-premises solution. Microsoft provides resources for customers to address exit planning, including its exit planning guidelines for financial services institutions and exit planning white paper. The financial institution still needs to examine any critical business or technical processes that rely on cloud services and establish their own internal end-to-end disaster recovery or business continuity plan (DRP/BCP) to deal with any outages that affect access those services. This includes power issues/failures within the organization, network failures and 3rd-party supplier outages such as cloud services, ISP, or DNS. Microsoft recommends reviewing the M365 Resiliency & Customer Guidance white paper for further guidance on incorporating these considerations into your BCP.

REF.	QUESTION / REQUIREMENT	GUIDANCE
52	What are the data backup and recovery arrangements for your organisation's data that resides with the service provider? (continued)	Paragraph 49 EBA Outsourcing Guidelines Business continuity plans should take into account the possible event that the quality of the provision of the outsourced critical or important function deteriorates to an unacceptable level or fails. Such plans should also take into account the potential impact of the insolvency or other failures of service providers and, where relevant, political risks in the service provider's jurisdiction Article 31(2)(k) MOR The investment firm and the service provider have established, implemented and maintained a contingency plan for disaster recovery and periodic testing of backup facilities, where that is necessary having regard to the function, service or activity that has been outsourced; Article 274(5)(d) SolReg The insurance or reinsurance undertaking that is outsourcing critical or important operational functions or activities shall ensure that the service provider has adequate contingency plans in place to deal with emergency situations or business disruptions and periodically tests backup facilities where necessary, taking into account the outsourced functions and activities. Microsoft conducts disaster recovery tests at least once per year. By way of background, Microsoft maintains physical redundancy at the server, datacenter, and service levels; data redundancy with robust failover capabilities; and functional redundancy with offline functionality. Microsoft's redundant storage and its procedures for recovering data are designed to attempt to reconstruct customer data in its original or last-replicated state from before the time it was lost or destroyed. Microsoft maintains multiple live copies of data at all times. Live data is separated into "fault zones," which ensure continuous access to data. For Office 365, Microsoft maintains multiple copies of customer data across datacenters for redundancy. For Azure, Microsoft may copy customer data between regions within a given geography for data redundancy or other operational purposes. For example, Azure Globally-Redundant Storage ("GRS") replicates certain data between two regions within the same geography for enhanced data durability in case of a major datacenter disaster.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
52	What are the data backup and recovery arrangements for your organisation's data that resides with the service provider? (continued)	To promote data resiliency, Microsoft Online Services offer active load balancing, automated failover and human backup, and recovery testing across failure domains as further described below. For example, Azure Traffic Manager provides load balancing between different regions, and the customer can use network virtual appliances in its Azure Virtual Networks for application delivery controllers (ADC/load balancing) functionality. Load balancing is also provided by Power BI Services, the Gateway, and Azure API Management roles. Office 365 services have been designed around specific resiliency principles that are designed to protect data from corruption, to separate data into different fault zones, to monitor data for failing any part of the ACID test, and to allow customers to recover on their own. For more information, refer to Microsoft's white paper "Data Resiliency in Microsoft Office 365," available at https://aka.ms/Office365DR. Redundancy - Physical redundancy at server, datacenter, and service levels. Data redundancy with robust failover capabilities. - Functional redundancy with offline functionality. Microsoft's redundant storage and its procedures for recovering data are designed to attempt to reconstruct customer data in its original or last-replicated state from before the time it was lost or destroyed. Additionally, Microsoft maintains multiple live copies of data at all times. Live data is separated into "fault zones", which ensure continuous access to data. For Office 365, Microsoft maintains multiple copies of customer data across for redundancy. For Azure, Microsoft may copy customer data between regions within a given geography for data redundancy or other operational purposes. For example, Azure Globally-Redundant Storage replicates certain data between two regions within the same geography for enhanced data durability in case of a major datacenter disaster. Resiliency - Active/active load balancing. - Automated failover with human backup. - Recovery testing across failure domains.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
52	What are the data backup and recovery arrangements for your organisation's data that resides with the service provider? (continued)	For example, Azure Traffic Manager provides load balancing between different regions, and the customer can use network virtual appliances in its Azure Virtual Networks for application delivery controllers (ADC/load balancing) functionality. Load balancing is also provided by Power BI Services, the Gateway, and Azure API Management roles. Office 365 services have been designed around specific resiliency principles that are designed to protect data from corruption, to separate data into different fault zones, to monitor data for failing any part of the ACID test, and to allow customers to recover on their own. Distributed Services • Distributed component services like Exchange Online, SharePoint Online, and Skype for Business Online limit scope and impact of any failures in a component. Directory data replicated across component services insulates one service from another in any failure events. • Simplified operations and deployment. Monitoring • Internal monitoring built to drive automatic recovery. • Outside-in monitoring raises alerts about incidents. • Extensive diagnostics provide logging, auditing, and granular tracing. Simplification • Standardised hardware reduces issue isolation complexities. • Fully automated deployment models. • Standard built-in management mechanism.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
52	What are the data backup and recovery arrangements for your organisation's data that resides with the service provider?	Human Backup • Automated recovery actions with 24/7 on-call support. • Team with diverse skills on the call provides rapid response and resolution. • Continuous improvement by learning from the on-call teams. Continuous Learning • If an incident occurs, Microsoft does a thorough post-incident review every time. • Microsoft's post-incident review consists of analysis of what happened, Microsoft's response, and Microsoft's plan to prevent it in the future. • If the organisation was affected by a service incident, Microsoft shares the post-incident review with the organisation.
53	What are the data and system security obligations of the service provider and how does the financial institution monitor compliance with these requirements? (continued)	Paragraph 82 EBA Outsourcing Guidelines Financial institutions should define data and system security requirements within the outsourcing agreement and monitor compliance with these requirements on an ongoing basis. Article 274(3)(f) SolReg The service provider is subject to the same provisions on the safety and confidentiality of information relating to the insurance or reinsurance undertaking or to its policyholders or beneficiaries that are applicable to the insurance or reinsurance undertaking. AT 9 No. 7(e) MaRisk In the case of material outsourced activities and processes, the outsourcing contract shall include rules ensuring compliance with data protection provisions and other security requirements.

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
53	What are the data and system security obligations of the service provider and how does the financial institution monitor compliance with these requirements?	Sec. V. 5 of the BaFin Guidance Provisions ensuring compliance with data protection regulations and other security requirements are to be agreed. The Product Terms, incorporating the Data Protection Terms, provide for the technical and organizational measures committed to in the provision of the Online Services. In addition, these terms specify the audit and monitoring mechanisms that Microsoft puts in place to verify that the Online Services meet appropriate security and compliance standards. Rigorous third-party audits validate the adherence of Microsoft Online Services to these strict requirements. Upon request, Microsoft will provide each Microsoft audit report to a customer to verify Microsoft's compliance with the security obligations under the Data Protection Terms. The Financial Services Terms provide additional mechanisms for oversight. Microsoft also provides detailed information to customers about its security practices so that customers can carry out their risk assessment. Refer to: the Service Trust Portal (Data Protection Resources); Microsoft's Security Documentation; Microsoft's Penetration Testing Rules of Engagement; the Microsoft Online Services Bounty Program; and downloadable audit reports available on the Service Trust Portal, for the latest privacy, security, and compliance-related information for Microsoft's cloud services.
54	How frequently does the service provider update their risk assessment?	Paragraph 102 EBA Outsourcing Guidelines Financial institutions should regularly update their risk assessment and should periodically report to the management body on the risks identified in respect of the outsourcing of critical or important functions. AT 9 No. 9 MaRisk The financial institution shall appropriately manage the risks associated with material outsourced activities and processes and shall properly monitor the provision of the outsourced activities and processes. This shall include regularly evaluating the external service provider's performance on the basis of defined criteria. Microsoft conducts a risk assessment for the Online Services at least annually to identify internal and external threats and associated vulnerabilities in the environment. Information is gathered from numerous data sources within Microsoft through interviews, workshops, documentation review, and analysis of empirical data.

REF.	QUESTION / REQUIREMENT	GUIDANCE
55	Does the financial institution check that the service provider has adequate risk management procedures and contingency plans? (continued)	Paragraph 48 EBA Outsourcing Guidelines Financial institutions should have in place, maintain and periodically test appropriate business continuity plans with regard to outsourced critical or important functions. Institutions and payment institutions within a group or institutional protection scheme may rely on centrally established business continuity plans regarding their outsourced functions. Paragraph 49 EBA Outsourcing Guidelines Business continuity plans should take into account the possible event that the quality of the provision of the outsourced critical or important function deteriorates to an unacceptable level or fails. Such plans should also take into account the potential impact of the insolvency or other failures of service providers and, where relevant, political risks in the service provider's jurisdiction Paragraph 104 EBA Outsourcing Guidelines Financial institutions should ensure, on an ongoing basis, that outsourcing arrangements, with the main focus being on outsourced critical or important functions, meet appropriate performance and quality standards in line with their policies by: (a) ensuring that they receive appropriate reports from service providers; (b) evaluating the performance of service providers using tools such as key performance indicators, key control indicators, service delivery reports, self-certification and independent reviews; and (c) reviewing all other relevant information received from the service provider, including reports on business continuity measures and testing. Article 31(2)(c) MOR Investment firms shall take the necessary steps to ensure the service provider properly supervises the carrying out of the outsourced functions, and adequately manage the risks associated with the outsourcing Article 274(5)(d) SolReg The insurance or reinsurance undertaking that is outsourcing critical or important operational functions or activities shall ensure that the service provider has adequate contingency plans in place to deal with emergency situations or business disruptions and periodically tests backup facilities where necessary, taking into account the outsourced functions and activities

Continued Next Page »

REF.	QUESTION / REQUIREMENT	GUIDANCE
55	Does the financial institution check that the service provider has adequate risk management procedures and contingency plans?	Risk management at Microsoft is designed to anticipate new threats and provide ongoing security for our cloud systems and the customers who use them. Microsoft's risk management activities are governed by the Enterprise Risk Management ("ERM") program. ERM enables the overall enterprise risk management process and works with management across the enterprise to identify and ensure accountability for Microsoft's most significant risks. It focuses on anticipating, assessing, and reporting risks to inform Microsoft's business strategy and drive risk mitigation and accountability. Microsoft ERM coordinates risk management activities across the enterprise to enable business units to independently facilitate consistent and comparative risk assessments. This provides Microsoft the ability to aggregate and report risk information in a consolidated manner for management. ERM provides business units in Microsoft with common methodologies, tools, and goals for the risk management process. Microsoft 365 and other engineering groups and business units leverage these tools to conduct individual risk assessments as part of their own risk management programs under the guidance of ERM. See Microsoft's Risk Management Overview for more details.

REF.	QUESTION / REQUIREMENT	GUIDANCE
56	What process does the financial institution have when outsourcing to service providers located in third-countries?	Paragraph 67 EBA Outsourcing Guidelines Where the outsourcing arrangement includes the possibility that the service provider sub-outsources critical or important functions to other service providers, institutions and payment institutions should take into account: (a). the risks associated with sub-outsourcing, including the additional risks that may arise if the sub-contractor is located in a third country or a different country from the service provider; (b). the risk that long and complex chains of sub-outsourcing reduce the ability of institutions or payment institutions to oversee the outsourced critical or important function and the ability of competent authorities to effectively supervise them. Article 32 MOR Where an investment firm outsources functions related to the investment service of portfolio management provided to clients to a service provider located in a third country, that investment firm ensures that the following conditions are satisfied: a. the service provider is authorised or registered in its home country to provide that service and is effectively supervised by a competent authority in that third country; and b. there is an appropriate cooperation agreement between the competent authority of the investment firm and the supervisory authority of the service provider. Microsoft has data centers and operates in the European Union. Microsoft offers a combination of tools and resources which are specifically designed to facilitate this risk assessment, including the Service Trust Portal which offers access to a deep set of security, privacy and compliance resources.

Part 2: Contract Checklist

WHAT ARE OUR CONTRACT DOCUMENTS?

The following table sets out the relevant Microsoft documents:

CORE MICROSOFT CONTRACT DOCUMENTS Microsoft Business and Services Agreement (MBSA); Enterprise Agreement (EA); and the enabling Enrollment , which is likely to be either an Enterprise Enrollment or a Server and Cloud Enrollment. Together, the agreements referenced here make up the “ Microsoft Agreement ”.	DOCUMENTS INCORPORATED IN MICROSOFT CONTRACTS¹ Product Terms (Product Terms), incorporating the Data Protection Addendum including the EU Model Clauses (DPA); Online Services Service Level Agreement (SLA).
AMENDMENT PROVIDED BY MICROSOFT TO ADD TO CORE CONTRACT DOCUMENTS FOR FINANCIAL SERVICES CUSTOMERS Financial Services Amendment (FSA)	SUPPORTING DOCUMENTS AND INFORMATION THAT DO NOT FORM PART OF THE CONTRACT² Materials available from the relevant Trust Center and <u>Microsoft Compliance</u>

WHAT DOES THIS PART 2 COVER?

This Part 2 sets out those specific items that must be addressed in your agreement, and the third column indicates how and where in the Microsoft contractual documents the mandatory requirement is covered.

¹ Available at www.microsoft.com/contracts.

² Available at www.microsoft.com/trustcenter.

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(a), EBA Outsourcing Guidelines Article 31(3) MOR Article 274(3) (c) and 274(4) (a) SolReg AT 9 No. 7 lit. a) MaRisk Sec. V. 1. of the BaFin Guidance	The scope of the arrangement and services to be supplied	The Online Services are described in the Microsoft Agreement. An online description is also available here: • <u>Microsoft 365 Service Description</u> • <u>Dynamics 365 Service Description</u> • <u>Directory of Azure Cloud Services</u> The support services, including Professional Services, are described in the DPA and in the Master Business Services Agreement.
Section 75(b), EBA Outsourcing Guidelines Article 274(4) (d) SolReg AT 9 No. 7 lit. a) MaRisk Sec. V. 1. of the BaFin Guidance	Commencement, end dates and notice period (long enough to enable the financial institution to find an alternative solution)	Refer to the Microsoft Agreement. In general, standard EA Enrollments have a three-year term and may be renewed for a further three-year term.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(c), EBA Outsourcing Guidelines	Governing law	Refer to the Microsoft Agreement. The agreements are governed by Irish law. The purchase agreement agreed with the German Microsoft entity is governed by German law.
Section 75(d), EBA Outsourcing Guidelines	Financial obligations	Refer to the Microsoft Agreement. In general, the customer is required by the EA to commit to an order for the quantities of services to be used. The pricing for the online services is specified in the Customer Price Sheet and each customer's order. In general, the customer is required by the EA to commit to annual payments (payable in advance) based upon the customer's number of users.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(e), 76 and 78 EBA Outsourcing Guidelines Article 31(3), MOR Article 274(4) (k) and 274(4) (l) SolReg AT 9 No. 7 lit. g) and No. 8 MaRisk Sec. V. 7. of the BaFin Guidance	Sub-outsourcing • specifying any types of activities that are excluded from sub-outsourcing; • specifying the conditions to be complied with in the case of sub-outsourcing; • specifying that the service provider is obliged to oversee those services that it has sub-outsourced; • requiring the service provider to obtain prior specific or general written authorisation from the financial institution before sub-outsourcing data; • obliging the service provider to inform the financial institution of any planned sub-outsourcing, or material changes thereto; • including the right to object to intended sub-outsourcing, or material changes thereof, or that explicit approval is required; and • including the right to terminate the agreement in the case of undue sub- outsourcing (continued)	Microsoft's enterprise cloud services process various categories of data, including customer data and personal data. Where Microsoft hires a subcontractor to perform work that may require access to such data, they are considered a subprocessor. Subprocessors may access data only to deliver the functions in support of Online Services that Microsoft has hired them to provide and are prohibited from using data for any other purpose. The Microsoft Online Services Subprocessor List identifies subprocessors authorized to subprocess customer data or personal data in Microsoft Online Services. This list is applicable for the Microsoft Online Services referred to in the Product Terms for which Microsoft is a data processor. This list of subprocessors includes all subcontractors who may perform critical or important functions and, in fact, discloses a set of subcontractors that perform staff augmentation, which itself is neither critical or important in the context of the provision of Online Services. For further information, refer to the Trust Center and the Subprocessor and Data Privacy White Paper. Microsoft gives customers notice of new subprocessors (by updating the Microsoft Online Services Subprocessor List and providing customers with a mechanism to obtain notice of that update) at least six months in advance of the subprocessor's authorization to perform services that may involve secure access to customer data and at least thirty days in advance of potential access to personal data within Microsoft Online Services. This advance notice enables customers to investigate the subprocessor, perform a risk assessment, and ask questions of Microsoft about the subprocessing engagement. (See DPA, "Notice and Controls on use of Subprocessors")

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(e), 76 and 78 EBA Outsourcing Guidelines Article 31(3), MOR Article 274(4) (k) and 274(4) (l) SolReg AT 9 No. 7 lit. g) and No. 8 MaRisk Sec. V. 7. of the BaFin Guidance	Sub-outsourcing • specifying any types of activities that are excluded from sub-outsourcing; • specifying the conditions to be complied with in the case of sub-outsourcing; • specifying that the service provider is obliged to oversee those services that it has sub-outsourced; • requiring the service provider to obtain prior specific or general written authorisation from the financial institution before sub-outsourcing data; • obliging the service provider to inform the financial institution of any planned sub-outsourcing, or material changes thereto; • including the right to object to intended sub-outsourcing, or material changes thereof, or that explicit approval is required; and • including the right to terminate the agreement in the case of undue sub- outsourcing	To ensure subcontractor accountability, Microsoft requires all of its vendors that handle customer personal information to join the Microsoft Supplier Security and Privacy Assurance Program, which is an initiative designed to standardise and strengthen the handling of customer personal information, and to bring vendor business processes and systems into compliance with those of Microsoft. For more information regarding Microsoft's Supplier Security and Privacy Program, see microsoft.com/en-us/procurement/msp-requirements.aspx. Microsoft will enter into a written agreement with any subcontractor to which Microsoft transfers customer data that is no less protective than the Data Protection Addendum in the customer's contracts with Microsoft. In addition, Microsoft's ISO/IEC 27018 certification requires Microsoft to ensure that its subcontractors are subject to the same security controls as Microsoft. Microsoft's ISO 27001 certification provides a layer of additional controls that impose stringent requirements on Microsoft's subcontractors to comply fully with Microsoft's privacy, security, and other commitments to its customers, including requirements for handling sensitive data, background checks, and non-disclosure agreements.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(f), EBA Outsourcing Guidelines Sec. V. 5. of the BaFin Guidance	Location where the outsourced services will be performed and where relevant data will be kept and processed	Information about the locations of customer data at rest for Core Online Services is available in the Product Terms and the DPA, which provides commitments on the location at which Microsoft will store customer data at rest. Additional information pertaining to the data residency and transfer policies specific to the Online Service is available at the Trust Center . This website lets you validate for each Online Service individually how data is stored and processed by Microsoft.
Section 75(g), EBA Outsourcing Guidelines	Accessibility, availability, integrity, privacy and safety of relevant data	The Microsoft Agreement includes various confidentiality, privacy and security protections. For information about how Microsoft cloud services protect your data, and how you can manage cloud data security and compliance for your organisation, refer to the Service Trust Portal (Data Protection Resources). The customer owns, and retains the ability to access, its data that is stored on Microsoft cloud services at all times. Refer to the Trust Center for further information.
AT 9 No. 7 lit. b) and c) MaRisk	Unrestricted information and audit rights and control options with respect to the outsourced activities and processes	The customer may monitor the performance of the Online Services via the administrative dashboard, which includes information as to Microsoft compliance with its SLA commitments. The DPA specifies the control standards and frameworks that Microsoft will comply with for each Online Service. The DPA also provides for independent audits of compliance of those Online Services, Microsoft remediation of issues raised by the audits and availability to customers of the audit reports and Microsoft information security policies.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Sec. V. 5. of the BaFin Guidance	The form in which data is to be kept and clear provisions identifying ownership and control of data (continued)	The customer will have the ability to access and extract its Customer Data stored in each Online Service at all times during the subscription and for a retention period of at least 90 days after it ends. Microsoft also makes specific commitments with respect to customer data in the Product Terms. In summary, Microsoft commits that: 1. Ownership of customer data remains at all times with the customer. 2. Customer data will only be used to provide the online services to the customer. Customer data will not be used for any other purposes, including for advertising or other commercial purposes. 3. Microsoft will not disclose customer data to law enforcement unless it is legally obliged to do so, and only after not being able to redirect the request to the customer. Microsoft will implement and maintain appropriate technical and organisational measures, internal controls, and information security routines intended to protect customer data against accidental, unauthorised or unlawful access, disclosure, alteration, loss, or destruction. Microsoft will notify the customer if it becomes aware of any security incident, and will take reasonable steps to mitigate the effects and minimise the damage resulting from the security incident. MBSA section 3 deals with confidentiality. Under this section Microsoft commits not to disclose confidential information (which includes customer data) to third parties (unless required by law) and to only use confidential information for the purposes of Microsoft's business relationship with the customer. If there is a breach of the contractual confidentiality obligations by Microsoft, the customer would be able to bring a claim for breach of contract against Microsoft.

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Sec. V. 5. of the BaFin Guidance	The form in which data is to be kept and clear provisions identifying ownership and control of data	Upon expiration or termination, the customer can extract its data. As set out in the Product Terms, Microsoft will retain customer data stored in the Online Service in a limited function account for 90 days after expiration or termination of the customer's subscription so that the customer may extract the data. After the 90-day retention period ends, Microsoft will disable the customer's account and delete the customer data. Microsoft will disable the account and delete customer data from the account no more than 180 days after expiration or termination of customer's use of an Online Service. Ownership of documents, records and other data remain with the customer and at no point transfer to Microsoft or anyone else, so this does not need to be addressed through transition. Being a cloud services solution, ownership of software and hardware used to provide the service remains with Microsoft.
Section 75(h), EBA Outsourcing Guidelines Article 31(2)(b), MOR Article 31(2)(d), MOR Article 31(2)(e) MOR Article 274(4) (f) SolReg Article 274(4)(j) SolReg	Right to monitor the service provider's performance (continued)	Microsoft provides access to "service health" dashboards (<u>Office 365 Service Health Dashboard</u> and <u>Azure Status Dashboard</u>) providing real-time and continuous updates on the status of Microsoft Online Services. This provides your IT administrators with information about the current availability of each service or tool (and history of availability status), details about service disruption or outage and scheduled maintenance times. The information is provided online and via an RSS feed. As part of its certification requirements, Microsoft is required to undergo independent third-party auditing, and it shares with the customer the independent third party audit reports. Microsoft also makes available a wealth of resources online to provide transparency and assurance to customers in the Microsoft <u>compliance documentation dashboard</u>. The Financial Services Amendment provides customers and their auditors with the unrestricted rights of inspection and auditing related to the outsourcing arrangement, which includes specific rights of access to business premises for financial services customers via special contractual provisions designed for regulated customers in the financial services sector. Additionally, Financial Services Amendment provides

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(h), EBA Outsourcing Guidelines Article 31(2) (b), MOR Article 31(2) (d), MOR Article 31(2) (e) MOR Article 274(4) (f) SolReg Article 274(4) (j) SolReg	Right to monitor the service provider's performance	the customer's regulator to examine or audit the Online Services in order to meet the regulator's supervisory obligations of Microsoft as a direct service provider of the customer. These rights enable such customers to comply with their regulatory obligations through direct access to business premises, to information, Microsoft personnel and Microsoft's external auditor. Customers may also participate in the optional Compliance Program for the Microsoft Cloud to obtain additional information concerning the Online Services, including the following: (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(i), EBA Outsourcing Guidelines Article 31(2) (b) MOR AT 9 No. 7 lit. a) MaRisk Sec. V. 1. of the BaFin Guidance	Service levels, which should include precise quantitative and qualitative performance targets	The SLA sets out Microsoft's service level commitments for Online Services, as well as the service credit remedies for the customer if Microsoft does not meet the commitment. Refer to: • <u>Microsoft 365 Service Level Agreement</u> • <u>Dynamics 365 Service Level Agreement</u> • <u>Azure Service Level Agreements</u>
Section 75(j), EBA Outsourcing Guidelines AT 9 No. 7 lit. h) MaRisk Sec. V. 8. of the BaFin Guidance	Reporting obligations	Notification of significant events Microsoft will notify the customer of the nature, common causes and resolution of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of the Online Services, and will provide communications regarding Microsoft's risk-threat evaluations and other circumstances that may have a serious impact. This is in addition to the various monitoring and reporting features already provided (see rows 22 and 25). Internal reports Microsoft commissions independent audits of the security of the computers, computing environment and physical data centres that it uses in processing customer/ personal data for each Online Service, the reports of which are available to customers on request. Customers also have access to the results of Microsoft's penetration testing.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(k), EBA Outsourcing Guidelines	Insurance	Microsoft maintains self-insurance arrangements for most of the areas where third party insurance is typically obtained. Copies of certificates of insurance are available upon request.
Section 75(l), EBA Outsourcing Guidelines Article 31(2) (l), MODR AT 9 No. 6 Ma Risk Sec. V. 5. of the BaFin Guidance	Requirement to implement and test business contingency plans	Microsoft has and will maintain adequate business continuity and disaster recovery plans intended to restore normal operations and proper provision of the Online Services in the event of an emergency. Such plans are documented, reviewed and tested at least annually. Microsoft will communicate with customers regarding significant changes to Microsoft's business resumption and contingency plans. For further information about Microsoft's approach to business continuity and disaster recovery, refer to our <u>Enterprise Business Continuity Management (EBCM) Program description</u>. We continually publish validation reports on our EBCM on a quarterly basis on our <u>website</u>.
Section 75(m), EBA Outsourcing Guidelines	Data access in case of the insolvency, resolution or discontinuation of business operations of the service provider.	Customers will at all times have access to customer data using the standard features of the Online Services, including in the case of the insolvency, resolution or discontinuation of business operations of Microsoft where the Data Retention and Deletion provisions in the Product Terms will apply. Additionally, the Financial Services Amendment requires Microsoft to continue to provide services in the event a regulator requires such continuance, including in the event of a termination of the agreement or a resolution of the financial institution.

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(n), EBA Outsourcing Guidelines Article 31(2) (h), MOR Article 274(4) (b) SolReg Sec. V. 3. of the BaFin Guidance	Obligation to cooperate with the competent authorities	The Financial Services Amendment details the parties' acknowledgment of the relevant regulators' and resolution authorities' information gathering and investigatory powers under applicable laws and that nothing in the Financial Services Amendment will limit or restrict such powers. Microsoft will cooperate with customers and their regulators to meet the regulator's supervisory obligations of Microsoft through unrestricted audit rights and direct access to customer data.
Section 75(o), EBA Outsourcing Guidelines	Clear reference to the national resolution authority's powers	Upon intervention by a national resolution authority, Microsoft will comply with the requirements of such national resolution authority. Further detail is set out in the Financial Services Amendment, which also provides for the continuation of services in the event of a resolution of the financial institution.
Section 75(p), EBA Outsourcing Guidelines Article 31(2) (i) MOR Article 274(4) (h) SolReg	Right of financial institutions to inspect and audit the service provider	Microsoft provides customers with the ability to access and extract customer data, as well audit and monitoring mechanisms, to enable customers to comply with their regulatory obligations. These rights of access and audit extend to regulators of customers. The Financial Services Amendment grants the customer unrestricted rights of inspection and auditing related to the outsourcing arrangement.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 75(q), EBA Outsourcing Guidelines Article 31(2) (g) MOR Article 274(4) (e) SolReg AT 9 No. 7 lit. f) MaRisk Sec. V. 6. of the BaFin Guidance	Termination rights (without detriment to the continuity and quality of its provision of services), including where: - the provider of the outsourced functions is in a breach - impediments capable of altering the performance of the outsourced function are identified - there are material changes affecting the outsourcing arrangement or the service provider - there are weaknesses regarding the management and security of confidential, personal or otherwise sensitive data or information - instructions are given by the financial institution's competent authority	The Microsoft Agreement includes rights to terminate early for cause and without cause. Refer to your Microsoft Agreement. Additionally, the Financial Services Amendment provides for the customer's right to terminate for Microsoft's breach of applicable law or its obligations under the Financial Services Amendment, as well as where customer can reasonably demonstrate that there are weaknesses regarding the management and security of customer data or there are material changes affecting Microsoft's provision of the Online Services.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 84, EBA Outsourcing Guidelines Article 31(2) (j), MOR 274(4)(g) SolReg AT 9 No. 7 lit. e) MaRisk Sec. V. 5. of the BaFin Guidance	Confidentiality, privacy and compliance with all legal requirements regarding the protection of data	Microsoft will comply with all privacy and data protection laws applicable to it in the provision of the Online Services. For information on how Microsoft handles your data in the cloud, refer to the <u>Subprocessor and Data Privacy White Paper</u>. Microsoft will not disclose confidential information (which includes customer data) to third parties (unless required by law) and will only use confidential information for the purposes of Microsoft's business relationship with the customer. In addition, Microsoft will ensure that its personnel engaged in the processing of customer and personal data will be obliged to maintain the confidentiality and security of such data even after their engagement ends.
AT 9 No. 7 lit. b) and c) MaRisk AT 9 No. 7 lit. d) MaRisk Sec. V. 4. of the BaFin Guidance Sec. V. 2. of the BaFin Guidance	Right to give instructions to the service provider (continued)	Microsoft also conducts regular penetration testing to increase the level of detection and protection throughout the Microsoft cloud. Microsoft makes available to customers penetration testing and other audits of its cybersecurity practices, and customers also may conduct their own penetration testing of the services. This is done in accordance with Microsoft's <u>rules of engagement</u>, which do not require Microsoft's permission in advance of such testing. For more information regarding penetration testing, see <u>https://technet.microsoft.com/en-us/mt784683.aspx</u>. Microsoft makes available certain tools through the <u>Service Trust Platform</u> to enable customers to conduct their own virtual audits of the Online Services. Microsoft also provides customers with information to reconstruct financial transactions and develop audit trail information through two primary sources: <u>Azure Active Directory</u> reporting, which is a repository of audit logs and other information that can be retrieved to determine who has accessed customer transaction information and the actions they

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
AT 9 No. 7 lit. b) and c) MaRisk	Right to give instructions to the service provider (continued)	have taken with respect to such information, and Azure Monitor , which provides activity logs and diagnostic logs that can be used to determine the “what, who, and when” with respect to changes to customer cloud information and to obtain information about the operation of the Online Services, respectively.
AT 9 No. 7 lit. d) MaRisk		
Sec. V. 4. of the BaFin Guidance		Microsoft enables financial institution customers to retain an appropriate level of control to meet their legal and regulatory obligations. Not only do you have full control and ownership over your data at all times, under the FSA Microsoft (i) makes available to you the written cloud services data security policy that complies with certain control standards and frameworks, along with descriptions of the security controls in place for Azure and other information that you reasonably request regarding Microsoft's security practices and policies; and (ii) causes the performance of audits, on your behalf, of the security of the computers, computing environment and physical datacenters that it uses in processing your data (including personal data) for the cloud services, and provides the audit report to you upon request. These arrangements are offered to you in order to provide you with the appropriate level of assessment of Microsoft's ability to facilitate compliance against your policy, procedural, security control and regulatory requirements.
Sec. V. 2. of the BaFin Guidance		You can further elect to participate in the Compliance Program for the Microsoft Cloud. This program allows you to engage with Microsoft during the term of the outsourcing contract to ensure that you have oversight over the services in order to ensure that the services meet your legal and regulatory obligations. Specifically, it enables you to have additional monitoring, supervisory and audit rights and additional controls over the cloud services, such as (a) access to Microsoft personnel for raising questions and escalations relating to the cloud services, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) receipt of communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
AT 9 No. 7 lit. b) and c) MaRisk AT 9 No. 7 lit. d) MaRisk Sec. V. 4. of the BaFin Guidance Sec. V. 2. of the BaFin Guidance	Right to give instructions to the service provider	be expected to have a material service impact on your use of the cloud services, (2) Microsoft's risk-threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on your use of Azure, (d) access to a summary report of the results of Microsoft's third party penetration testing against the cloud services (e.g. evidence of data isolation among tenants), and (e) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.
Section 85 EBA Outsourcing Guidelines	Ability of internal audit function to review the outsourced function using a risk-based approach (continued)	The Microsoft Financial Services Amendment provides for rights of audit, and additional customer benefits, including (a) access to community events organized by Microsoft related to updates to the Online Services, Microsoft responses to regulator changes, and to provide additional feedback to Microsoft for further development of the Online Services; (b) submit a written request to meet with Microsoft's external auditors; (c) receive from Microsoft written responses to updated regulator guidance; (d) receive responses from Microsoft about Microsoft responses and changes to services based on regulatory changes; (e) access Microsoft personnel for raising questions and escalations relating to Microsoft cloud services; (f) receive communication from Microsoft on (1) the nature, common causes, and resolutions of security incidents and other circumstances that can reasonably be expected to have a material service impact on the customer's use of Microsoft cloud services, (2) Microsoft's risk-threat evaluations, and (3) significant changes to Microsoft's business resumption and contingency plans or other circumstances that might have a serious impact on the customer's use of Microsoft cloud services, and (g) receive access to a summary report of the results of Microsoft's third party penetration testing against Microsoft cloud services (e.g. evidence of data isolation among tenants in the multi-tenanted services).

Continued Next Page »

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 85 EBA Outsourcing Guidelines	Ability of internal audit function to review the outsourced function using a risk-based approach	In addition, Microsoft offers the optional Compliance Program for the Microsoft Cloud, which provides for (a) access to Microsoft personnel for raising questions and escalations relating to Online Services, including for support in risk assessments, (b) invitation to participate in a webcast hosted by Microsoft to discuss audit results and subsequent access to detailed information regarding planned remediation of any deficiencies identified by the audit, (c) access to Microsoft's subject matter experts through group events such as webcasts or in-person meetings (including an annual summit event) where roadmaps of planned developments or reports of significant events will be discussed and you will have a chance to provide structured feedback and/or suggestions regarding the Compliance Program for the Microsoft Cloud and its desired future evolution. The group events will also give you the opportunity to discuss common issues with other regulated financial institutions and raise them with Microsoft.
Section 86, EBA Outsourcing Guidelines	Reference to refer to information gathering and investigatory powers of competent authorities with regard to service providers located in a Member State or third countries.	The Financial Services Amendment details the parties' acknowledgment of the relevant regulators' and resolution authorities' information gathering and investigatory powers under applicable laws and that nothing in the Financial Services Amendment will limit or restrict such powers. In addition to the audit rights discussed immediately above, the Financial Services Amendment provides the customer's regulator to examine or audit the Online Services in order to meet the regulator's supervisory obligations of Microsoft as a direct service provider of the customer.
Section 87(a), EBA Outsourcing Guidelines Article 31(2) (i) MOR Article 274(4) (h) SolReg	Access to all relevant business premises	Full access to business premises Microsoft permits any necessary examination or monitoring required to occur at Microsoft's offices or at other locations where activities relating to the Online Services are performed. The customer will also have the right to elect its auditor to undertake any such visit if necessary under these provisions. The Financial Services Amendment enables customers to comply with their regulatory obligations through direct access to business premises, to information, Microsoft personnel and Microsoft's external auditor.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 87(b), EBA Outsourcing Guidelines Article 31(2) (i) MOR Article 274(4) (h) SolReg	Unrestricted rights of inspection and auditing	Right to inspect and audit Customers may conduct their own virtual audits of the Online Services via tools available through the <u>Service Trust Portal</u>. In particular, refer to: • <u>Downloadable audit reports</u>; • <u>Security FAQs and white papers</u>; • <u>Audit Videos</u>; • <u>Compliance Manager; Security & Compliance (microsoft.com)</u> • <u>Self-paced Learning Path</u>; • <u>TruSight Independent Assessment Reports</u>. Customers also have access to third party audit reports commissioned by Microsoft.
Section 89, EBA Outsourcing Guidelines Article 31(2) (i) MOR Article 274(4) (h) SolReg	No impediment or limit on the effective exercise of the access and audit rights	Microsoft will provide unrestricted audit and access rights to customers and regulators per the Financial Services Amendment. The Financial Services Amendment provides the customer's regulator to examine or audit the Online Services in order to meet the regulator's supervisory obligations of Microsoft as a direct service provider of the customer.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 99 EBA Outsourcing Guidelines	Obligations of the existing service provider, in the case of a transfer of the outsourced function to another service provider or back to the financial institution, including - the treatment of data - appropriate transition period (during which the service provider would continue to provide the outsourced function to reduce the risk of disruptions) - an obligation of the service provider to support the financial institution in the orderly transfer of the function	See white papers on exit management available via the Service Trust Portal. Treatment of data on termination Customers are able to access, extract and delete customer data stored in each Online Service at all times during the term of the subscription and for a limited period after expiration or termination of the subscription. Ownership of documents, records and other data remain with the customer and at no point transfer to Microsoft or anyone else, so this does not need to be addressed through transition. Being a cloud services solution, ownership of software and hardware used to provide the service remains with Microsoft. The Financial Services Amendment provides for business continuity and exit provisions, including rights for the customer to obtain exit assistance at market rates from Microsoft Consulting Services. Customers should work with Microsoft to build such business continuity and exit plans. Microsoft's flexibility in offering hybrid solutions further facilitate transition from cloud to on-premise solutions more seamlessly.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Section 104(a), EBA Outsourcing Guidelines Article 31(2) (b) MOR Article 274(4) (f) SolReg Article 274(4) (j) SolReg	Performance and quality standards in line with financial institutions' policies by - ensuring that they receive appropriate reports from service providers - evaluating the performance of service providers using tools such as key performance indicators, key control indicators, service delivery reports, self-certification and independent reviews; and - reviewing all other relevant information received from the service provider, including reports on business continuity measures and testing.	Microsoft provides access to "service health" dashboards (<u>Office 365 Service Health Dashboard</u> and <u>Azure Status Dashboard</u>) providing real-time and continuous updates on the status of Microsoft Online Services. This provides your IT administrators with information about the current availability of each service or tool (and history of availability status), details about service disruption or outage and scheduled maintenance times. The information is provided online and via an RSS feed. As part of its certification requirements, Microsoft is required to undergo independent third-party auditing, and it shares with the customer the independent third party audit reports. Microsoft also makes available a wealth of resources online to provide transparency and assurance to customers in the Microsoft <u>compliance documentation dashboard</u>. Customers may also sign up for Premier Support, in which a designated Technical Account Manager serves as a point of contact for day-to-day management of the Online Services and the customer's overall relationship with Microsoft. Customers have various rights to receive information and reports, examine, monitor and audit Microsoft Online Services. In addition, as part of its certification requirements, Microsoft is required to undergo independent third party auditing and customers have access to those reports. These are available via the <u>Service Trust Portal</u>.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Article 31(2)(d), MOR	Provisions regarding appropriate action to be taken where it appears that the service provider may not be carrying out the functions effectively or in compliance with applicable laws and regulatory requirements	All of these aspects are covered in the Product Terms and the SLA. The Product Terms contains the privacy and security practices, and internal controls that Microsoft implements, and the SLA sets out Microsoft's service level commitments for Online Services, as well as the service credit remedies for the customer if Microsoft does not meet the commitment. The SLA is fixed for the initial term of the Enrollment. "We will not modify the terms of your SLA during the initial term of your subscription; however, if you renew your subscription, then the version of this SLA that is current at the time of renewal will apply for your renewal term." For information regarding uptime for each Online Service, refer to the <u>Service Level Agreement for Microsoft Online Services</u>. The customer may also terminate an Online Service at the express direction of a regulator with reasonable notice. Additionally, to ensure regulatory compliance, Microsoft and the Customer may contemplate adding additional products or services, or if these are unable to satisfy the customer's new regulatory requirements, the customer may terminate the applicable Online Service without cause by giving 60 days' prior written notice. Additionally, in order to facilitate your continued and ongoing legal and regulatory compliance needs, and as part of its standard offering to you (i.e. the FSA that automatically applies to regulated financial services institution customers), Microsoft agrees to discuss how to meet new or additional requirements imposed on you should you become subject to Future Applicable Law (as defined in the FSA).
Article 274(4)(b) SolReg Article 31(2)(a) MOR	Commitment to comply with all applicable laws, regulatory requirements and guidelines	Microsoft undertakes to comply with all laws and regulations applicable to its provision of the Online Services that are generally applicable to all the IT service providers.

REFERENCE	REQUIREMENT	HOW AND WHERE IS THIS DEALT WITH IN MICROSOFT'S CONTRACT?
Article 274(4) (c) SolReg Article 31(2) (f) MOR	Obligation to disclose any development which may have a material impact on service provider's ability to carry out the outsourced functions	The customer may elect to participate in the optional Compliance Program for the Microsoft Cloud. Through participation, Microsoft will provide Customer with the ability to (i) assess the controls that apply to each Online Service and the effectiveness of those controls, (ii) access data related to service operations, (iii) maintain insight into operational risks of the services, (iv) receive notification of changes that may materially impact Microsoft's ability to provide the Online Services, (v) engage with Microsoft subject matter experts and external auditors, and (vi) provide suggestions to improve the Online Services. Additionally, Microsoft provides access to "service health" dashboards (Office 365 Service Health Dashboard and Azure Status Dashboard) providing real-time and continuous updates on the status of Microsoft Online Services. This provides your IT administrators with information about the current availability of each service or tool (and history of availability status), details about service disruption or outage and scheduled maintenance times. The information is provided online and via an RSS feed.
Article 274(4) (i) SolReg	Where appropriate and necessary for the purposes of supervision, the supervisory authority may address questions directly to the service provider to which the service provider shall reply	Microsoft enables this by committing to regulatory oversight and examination. This necessarily includes addressing questions directly to it and responding to them, accordingly. As part of the Financial Services Amendment, customers may engage Microsoft with questions from customers, their auditors, or their regulators.
Sec. V. 9. of the BaFin Guidance	Choice of German law or the law of any other member state of the European Union or European Economic Area	The agreements are governed by Irish law. The purchase agreement agreed with the German Microsoft entity is governed by German law.

Further Information

- Navigating Your Way to the Cloud: microsoft.com/en-sg/apac/trustedcloud
- Compliance Documentation: <https://docs.microsoft.com/en-us/compliance/>
- Trust Center: microsoft.com/trust
- Service Trust Portal: aka.ms/trustportal
- Customer Stories: customers.microsoft.com
- Product Terms: Microsoft.com/contracts
- Service Level Agreements: microsoft.com/contracts
- SAFE Handbook: aka.ms/safehandbook
- A Cloud for Global Good | Microsoft: news.microsoft.com/cloudforgood/

© Microsoft Corporation 2019. This document is not legal or regulatory advice and does not constitute any warranty or contractual commitment on the part of Microsoft. You should seek independent legal advice on your cloud services project and your legal and regulatory obligations.